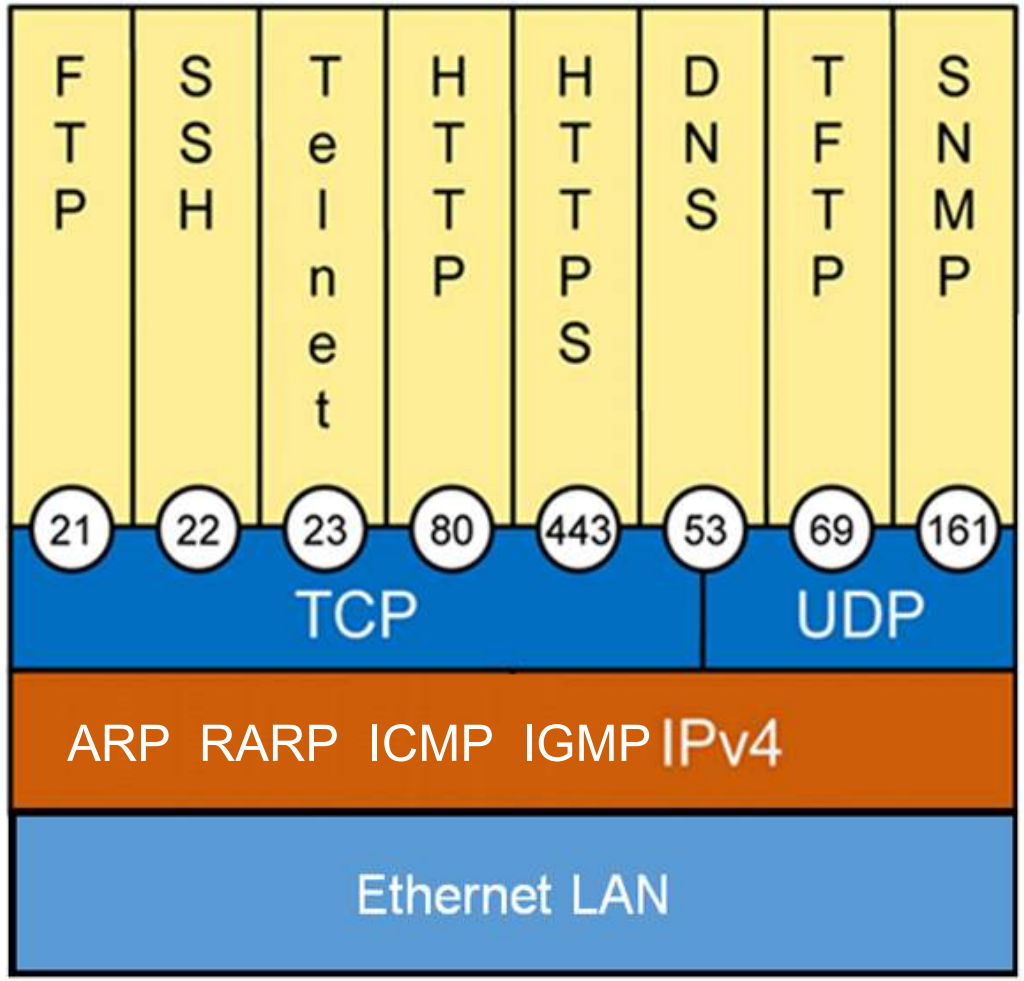
TCP/IP Protocol Stack



HTTP 네트워크 현황분석과 이상징후 분석

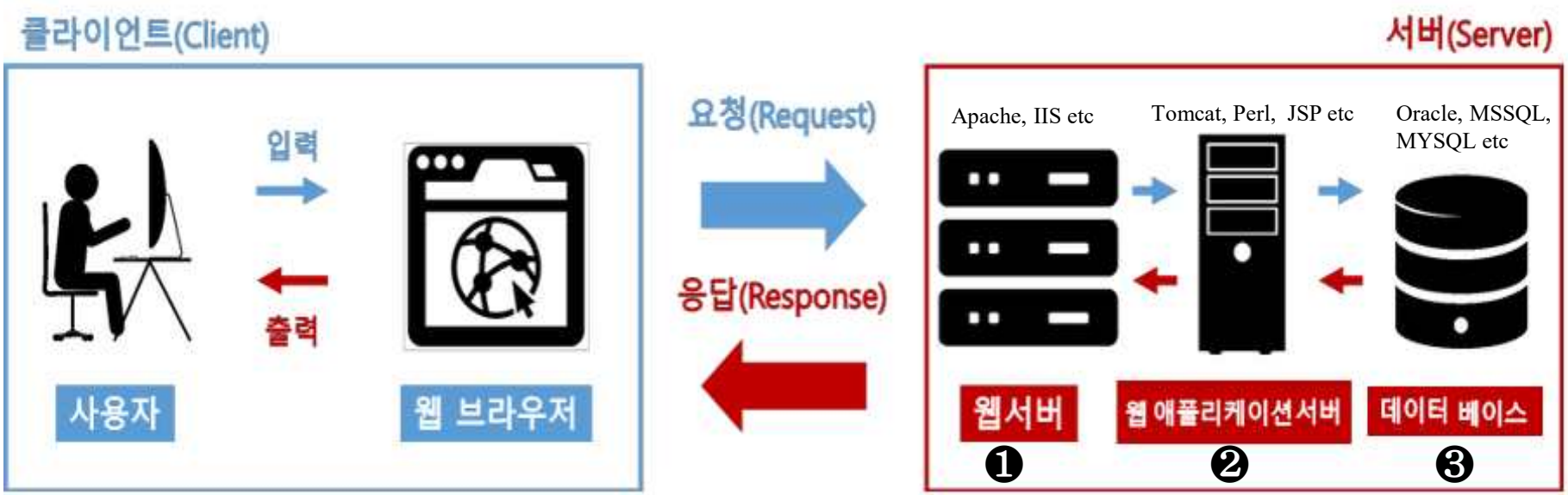
1) HTTP 이해

2) HTTP Log 실습환경 구성 (P.236)

3) HTTP 네트워크 현황분석 (P.249)

4) HTTP 이상징후(P.275)

3-Tier Web System Architecture



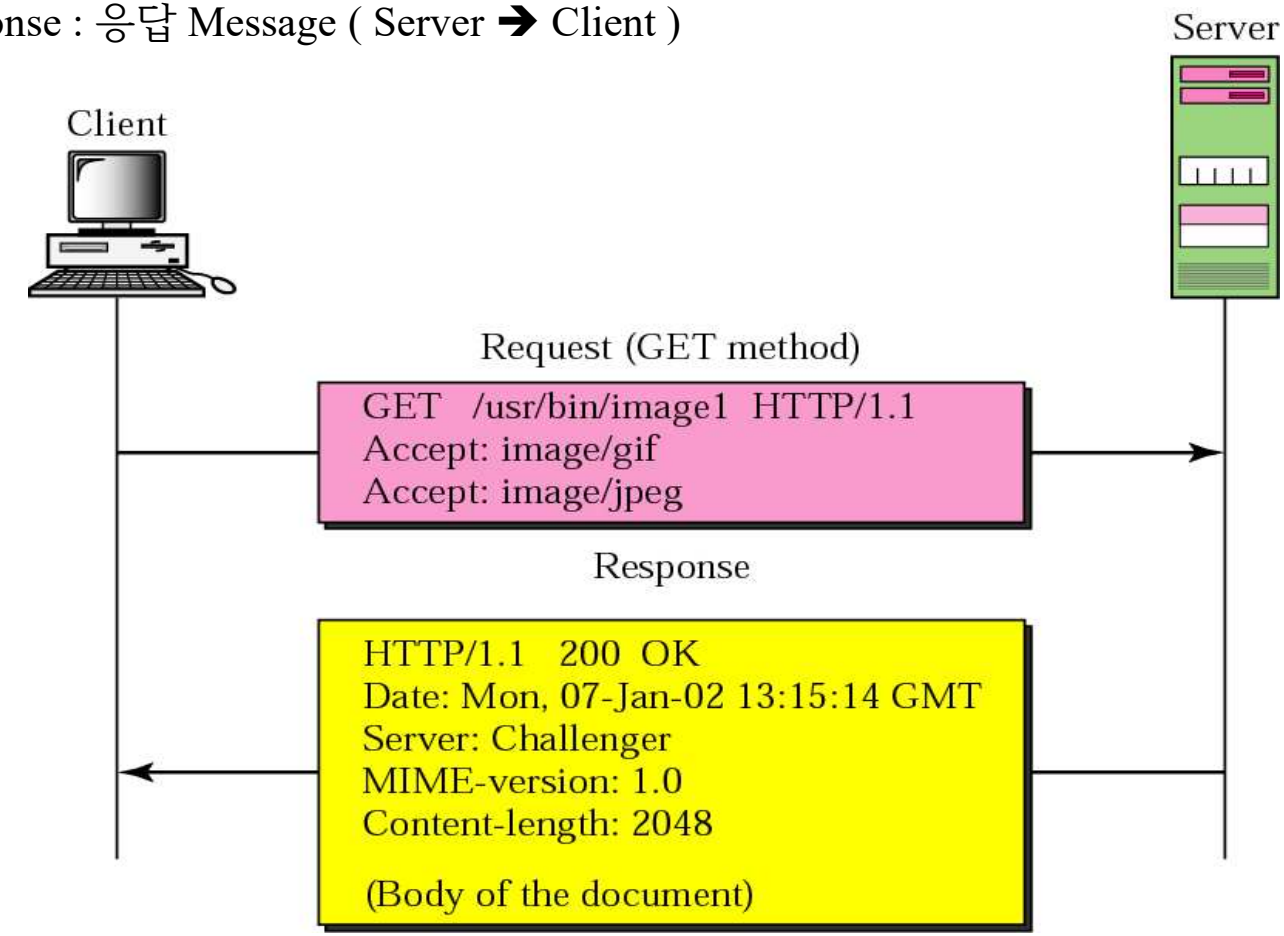
1) HTTP 이해

- WWW 상에서 HTML 문서를 주고 받는 응용 계층 프로토콜
- TCP 계열로 80번 포트 사용
- 웹에서 텍스트, 그래픽, 애니메이션을 보거나 사운드 재생 기능
- 클라이언트와 서버 사이에 이뤄지는 요청(request) / 응답 (response) 프로토콜
- 현재 인터넷에서 사용되는 HTTP 버전은 **HTTP/1.0, HTTP/1.1, HTTP/2.0** 임

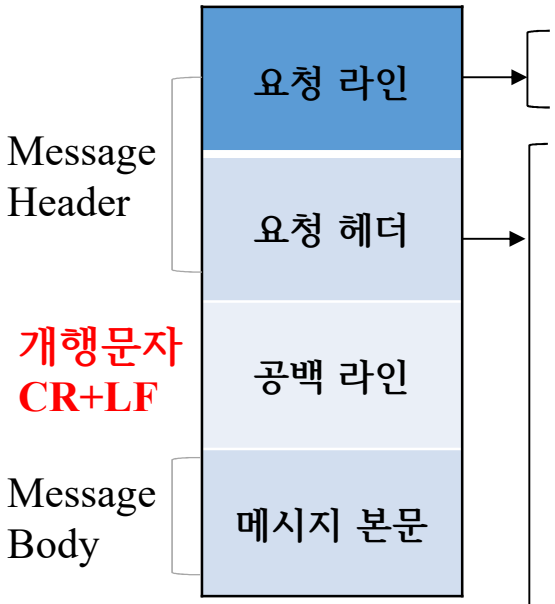
  - 1997년 1월에 공개된 HTTP/1.1 버전이 현재 가장 많이 사용
- <u>무상태(stateless) 프로토콜</u>

· Message Format

- Request : 요청 Message (Client ➔ Server)
- Response : 응답 Message (Server ➔ Client)



▪ HTTP Request Message




```
GET / HTTP/1.1
Accept: text/html, application/xhtml+xml, */*
Accept-Encoding: gzip, deflate
Cookie: HSID=AaxlkKoV2snlEi6UQ; SSID=AAYVu_evC0Tiu3aVc;
APISID=JEWp0eojRTLFtYKJ/ACgEWh_0mL8Li_-fl;
SAPISID=kabRBO-uT0ebDcfc/A2byDX--FwN649tHw
Host: www.google.com
Connection: Keep-Alive
Accept-Language: ko-KR
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Trident/5.0)
```

*** CR+LF**
- CR(Carriage Return) : 16진수 0x0d
- LF(Line Feed) : 16진수 0x0a

Request Method 종류

서버에 임무를 부여하는 HTTP 메소드

- GET
- POST
- HEAD
- OPTIONS
- PUT
- DELETE
- TRACE

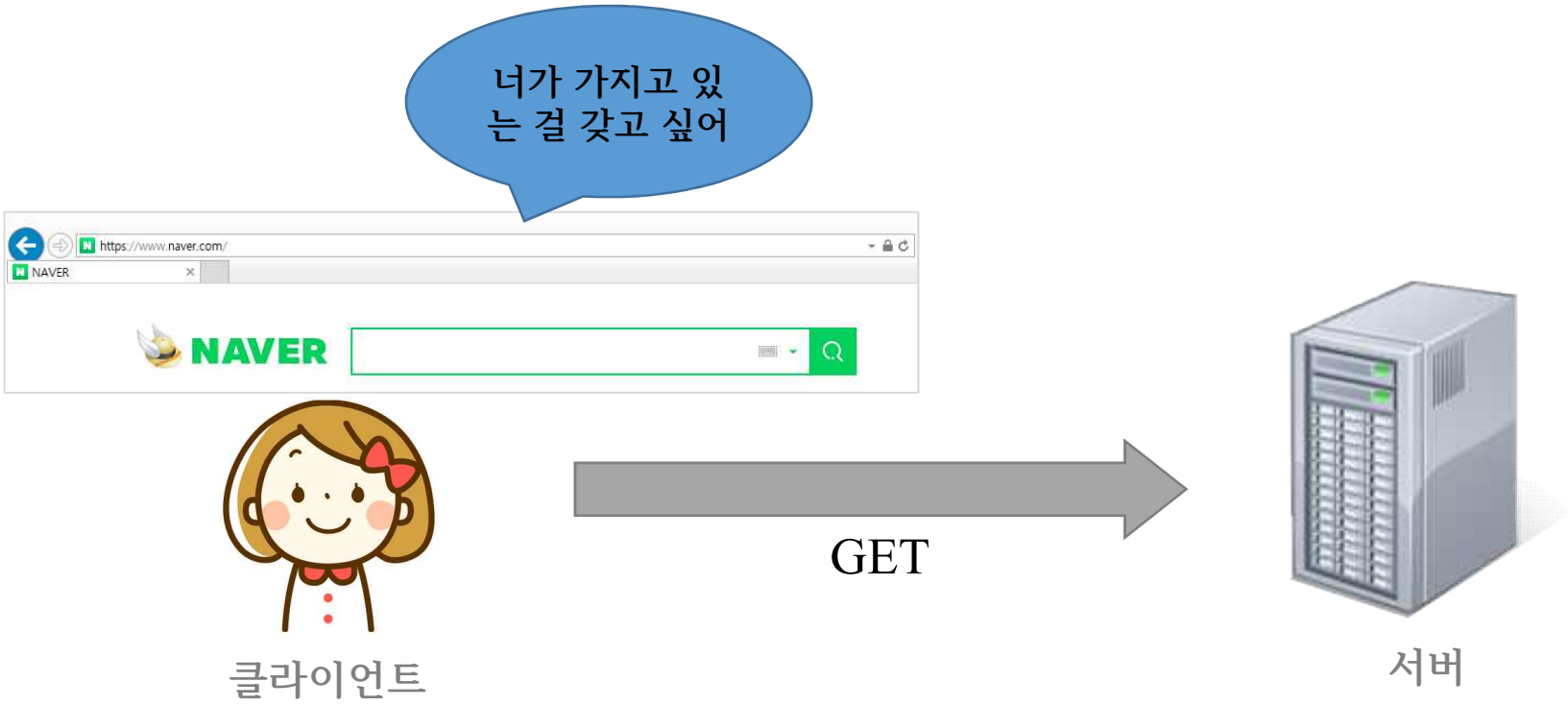
```
GET / HTTP/1.1
Accept: text/html, application/xhtml+xml, */*
Accept-Encoding: gzip, deflate
Cookie: HSID=AaxlkKoV2snlEi6UQ; SSID=AAYVu_evC0Tiu3aVc;
APISID=JEWp0eojRTLFtYKJ/ACgEWh_0mL8Li_-fl;
SAPISID=kabRBO-uT0ebDcfc/A2byDX--FwN649tHw
Host: www.google.com
Connection: Keep-Alive
Accept-Language: ko-KR
User-Agent: Mozilla/5.0 (compatible; MSIE 9.0; Windows NT 6.1; Trident/5.0)
```

HTTP Request : Get 방식

- 요청 데이터의 인수를 웹 브라우저의 URL로 전송함

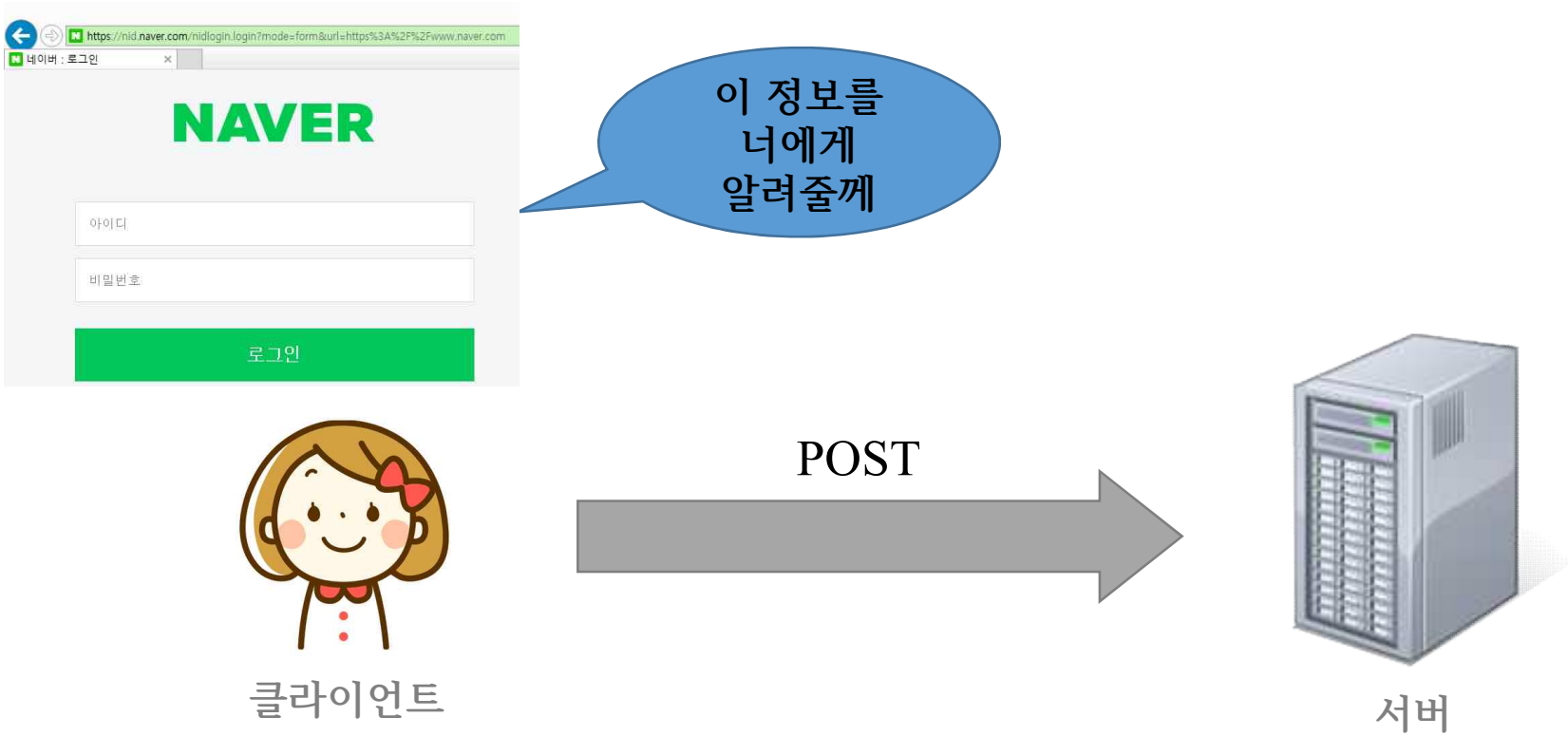
  - 데이터가 주소 입력란에 표시 (최소한의 보안도 유지되지 않는 취약한 방식)

- Request URI로 식별된 리소스를 가져올 수 있도록 요구



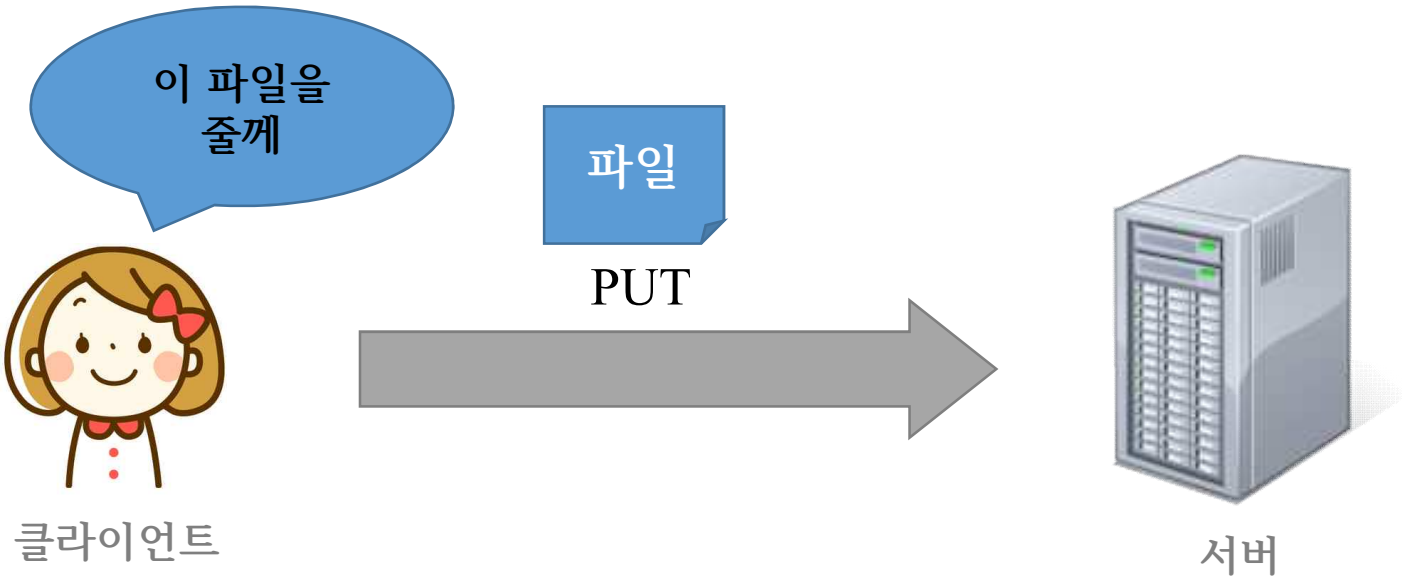
HTTP Request : POST 방식

- 엔티티를 전송하기 위해 사용
- URL에 요청 데이터를 기록하지 않고 HTTP 헤더에 데이터를 전송.
- 엔티티를 URL로 전송하지 않으므로 다른 사용자가 링크로 해당 페이지를 볼 수 없음



HTTP Request : PUT 방식

- POST와 유사한 전송 구조를 가짐
- Request 중에 포함된 엔티티를 Request URI로 지정한 곳에 보존하도록 요구
- 인증 기능 없이 누구든지 파일을 업로그 가능하다는 보안 상의 문제가 있음



HTTP Request : PUT 방식

- 홈페이지 변조에 많이 악용되고 있음

- PUT 방식으로 전달되는 URI는 파일의 이름 또는 경로
- 클라이언트가 지정한 위치에 특정 파일을 가져다 놓으려고 할 때 PUT 방식 사용
- 1234567890 이라는 내용이 입력된 file.txt 파일을 웹서버로 업로드

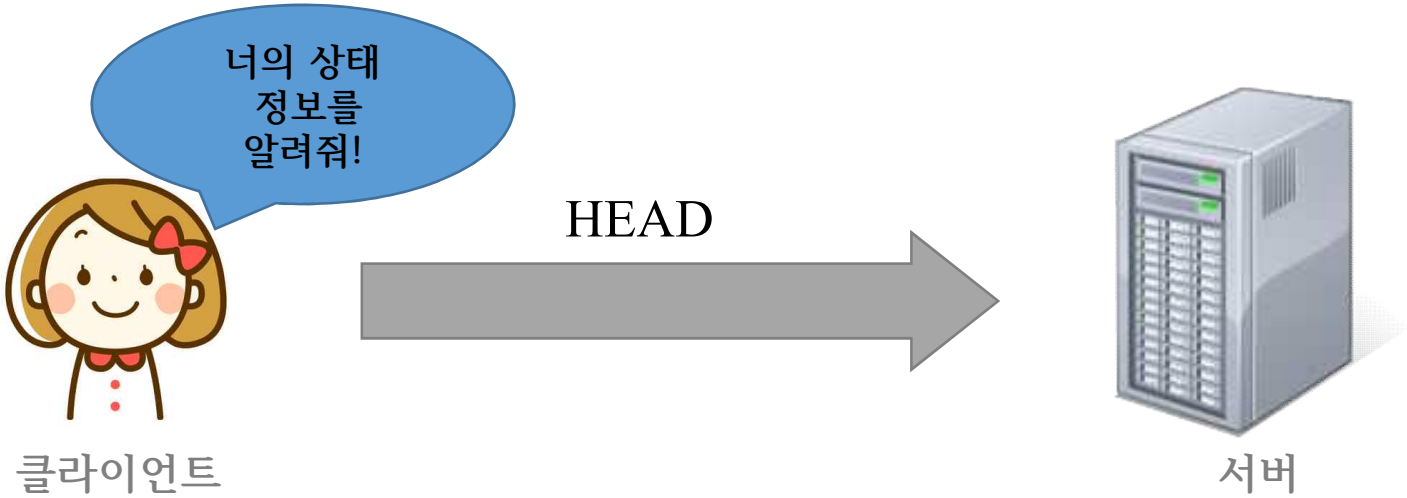
HTTP Request : Head 방식

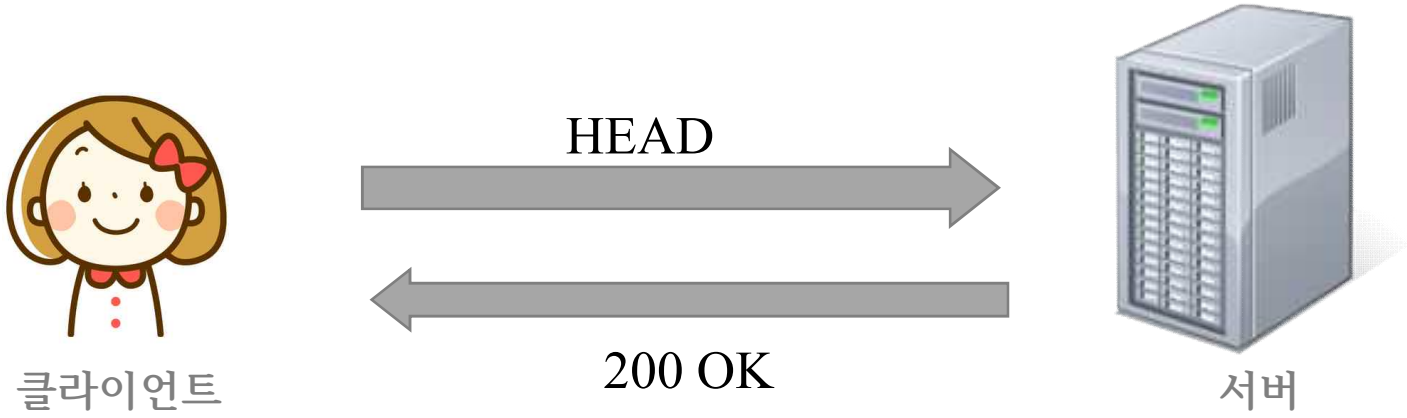
- GET방식과 동일
- 서버 측 데이터를 검색하고 요청하는 데 사용
- BODY가 없고 응답코드와 HEAD로만 응답

  - 서버의 응답 헤더를 봄으로써 Resource가 수정 되었는지 확인

- **URI 유효성과 리소스 갱신 시간을 확인하는 목적을 사용**

  - 웹 서버 정보확인, 헬스체크, 버전확인, 최종 수정일자 확인 용도



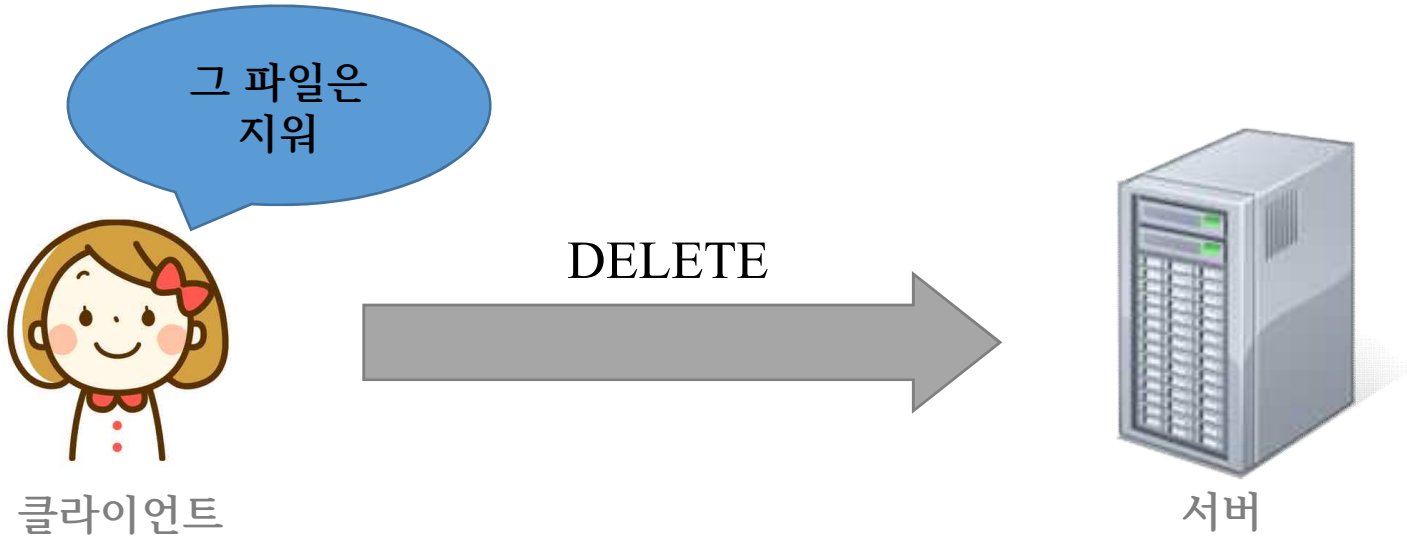


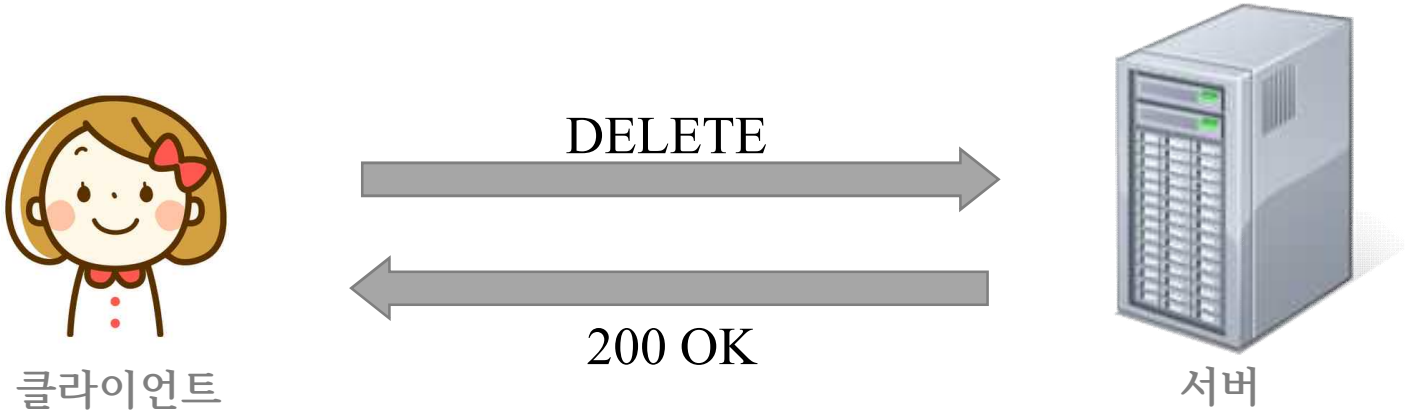

```
HEAD /index.html HTTP/1.1
Host: example.com

HTTP/1.1 200 OK
Content-Encoding: gzip
Accept-Ranges: bytes
Cache-Control: max-age=604800
Content-Type: text/html
Date: Thu, 21 Jul 2016 14:00:21 GMT
Etag: "359670651+gzip"
Expires: Thu, 28 Jul 2016 14:00:21 GMT
Last-Modified: Fri, 09 Aug 2013 23:54:35 GMT
Server: ECS (lga/1384)
X-Cache: HIT
x-ec-custom-error: 1
Content-Length: 606
```

HTTP Request : Delete 방식

- URI에 지정된 자원을 서버에서 지울 수 있게 함
- 원격지 웹 서버에 파일을 삭제하기 위해 사용되며 PUT과는 반대 메소드

```
DELETE /webdav/file.txt HTTP/1.1
host: 192.168.211.39
```

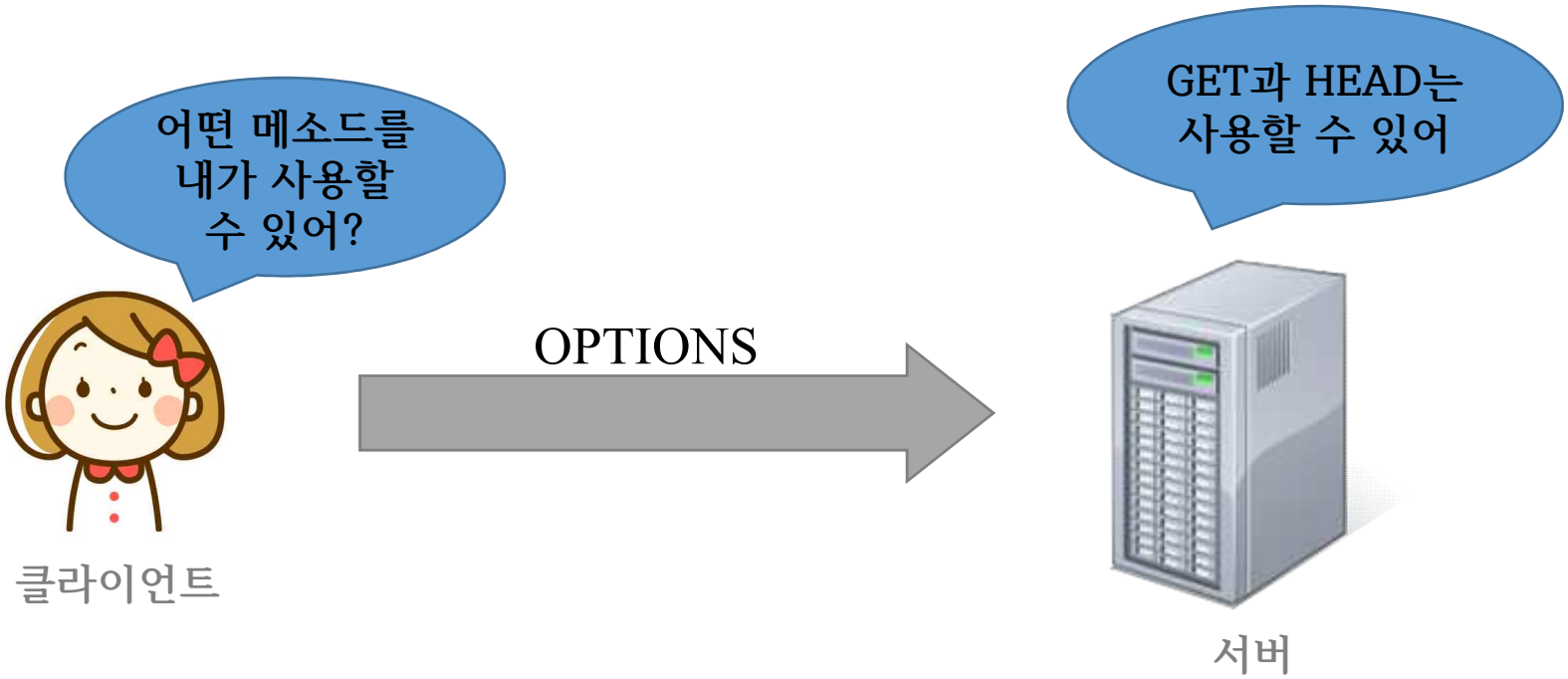


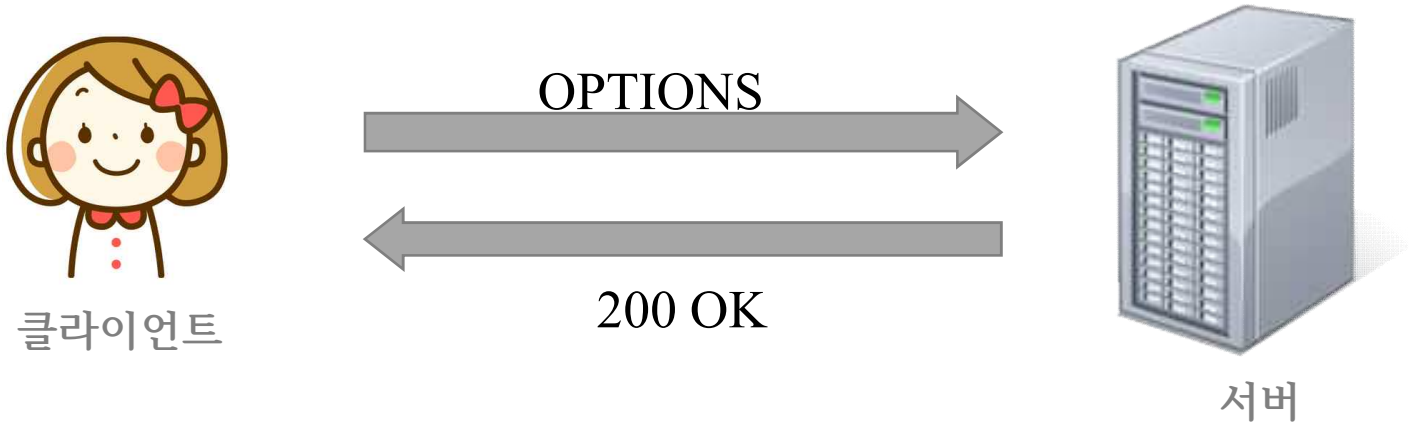



```
DELETE /index.jsp HTTP/1.1
Host: localhost

HTTP/1.1 200 OK
Set-Cookie: JSESSIONID=49FFC8F0301FCD88242EDD2B6AA99FF9; Path=/; HttpOnly
Content-Type: text/html;charset=UTF-8
Content-Length: 8
Date: Fri, 04 May 2018 00:25:20 GMT
Server: FakeServer
```

HTTP Request : Option 방식

- 자원에 대한 요구/응답 관계와 관련된 선택 사항 정보를 요청할 때 사용
- 시스템에서 지원되는 메소드 종류를 확인 할 수 있음
- 웹서버에서 지원하는 HTTP 요청방식을 확인하고자 할 때 사용



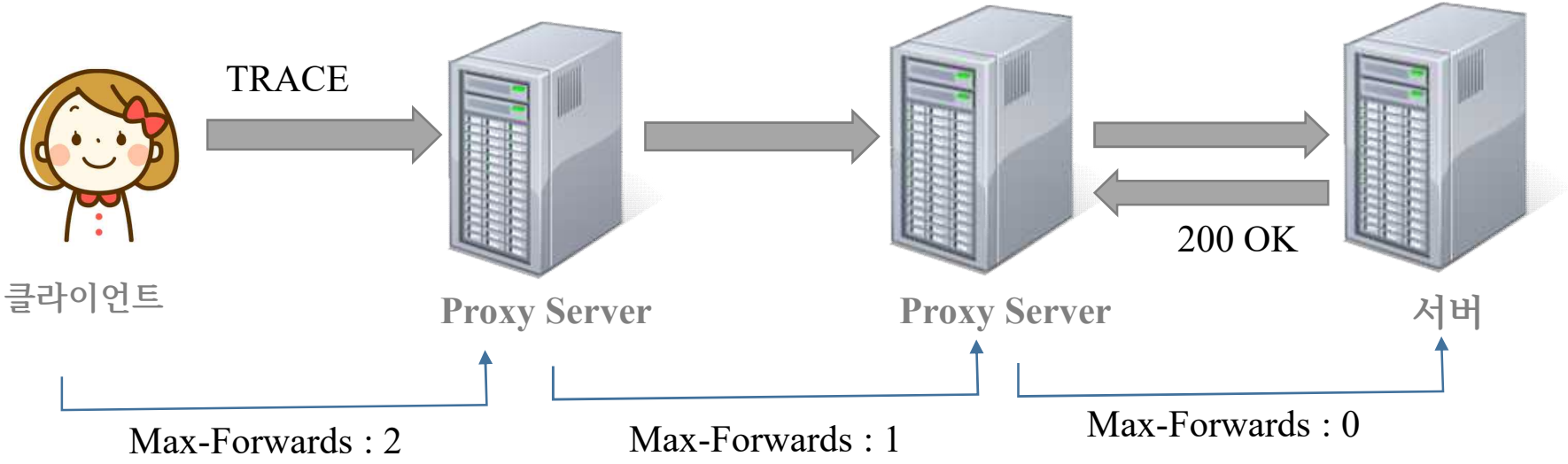



```
[root@AY2 ~]# telnet 192.168.211.39 80
Trying 192.168.211.39...
Connected to 192.168.211.39.
Escape character is '^]'.
OPTIONS /index.html HTTP/1.1
Host: 192.168.211.39

HTTP/1.1 200 OK
Date: Tue, 04 Jul 2017 00:28:01 GMT
Server: Apache/2.4.25 (Ubuntu)
Allow: GET,HEAD,POST,OPTIONS,HEAD,HEAD,TRACE
Content-Length: 0
Content-Type: text/html
```

HTTP Request : Trace 방식

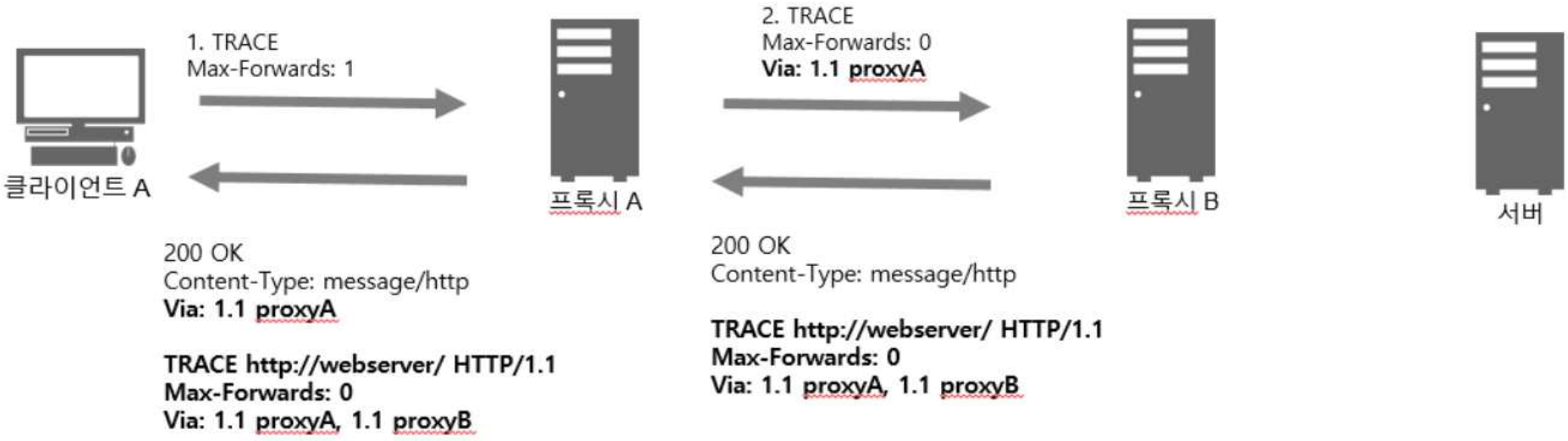
- 웹서버가 웹브라우저(클라이언트)에서 보낸 내용을 받아 이를 다시 웹 브라우저로 되돌려 주는 것 ➔ 클라이언트로 Loopback을 발생시킴
- 웹 서버로 가는 네트워크 경로를 체크하는 메소드
- Request를 보낼 때 "Max-Forwards"라는 헤더 필드에 수치를 포함

  - 서버를 통과할때마다 수치가 감소, 0이 된 곳을 끝으로 200 OK response를 되돌려줌



HTTP Via

- 정방향 및 역방향 프록시에 의해 추가
  - 요청헤더와 응답 헤더에 나타날 수 있음
- Forward 메시지를 추적하거나, 요청 루프 방지, 요청과 응답 체인에 따라 송신자의 프로토콜 정보를 식별



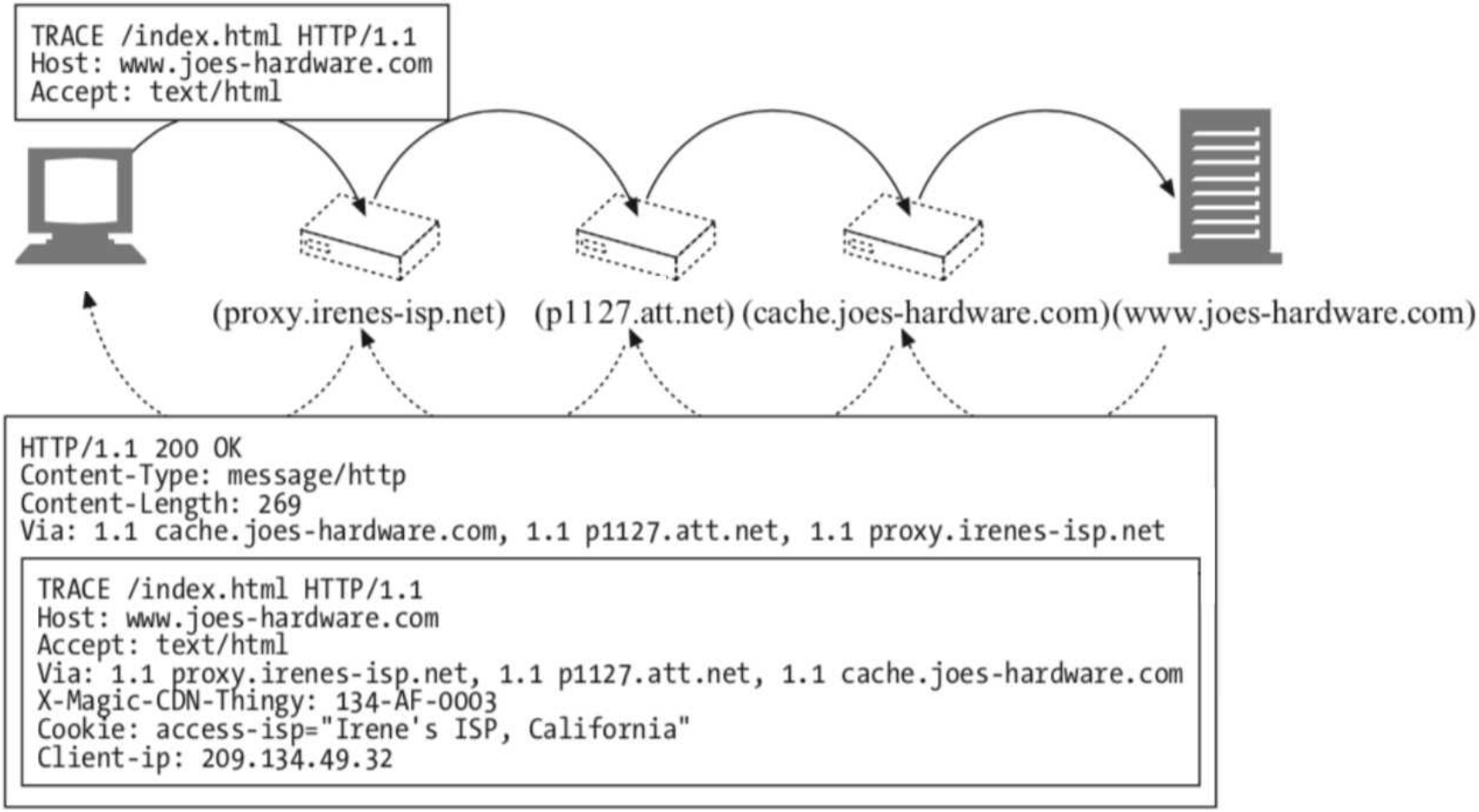
<<문법>>

```
Via: [ <protocol-name> "/" ] <protocol-version> <host> [ ":" <port> ]
or
Via: [ <protocol-name> "/" ] <protocol-version> <pseudonym>
```

내부Proxy 이름 또는 별칭

<<예제>>

```
Via: 1.1 vegur

Via: HTTP/1.1 GWA

Via: 1.0 fred, 1.1 p.example.net
```



- 웹서버가 웹브라우저(클라이언트)에서 보낸 내용을 받아 이를 다시 웹 브라우저로 되돌려 주는 것
- 공격자는 trace 기능을 이용하여 HTTP 헤더에 포함된 쿠키 혹은 인증 데이타 획득 가능

  - **XST(Cross Site Tracing)** 공격을 할 수 있는 위협이 존재

X-Forwarded-For(XFF)

- HTTP Server 에 요청한 client의 IP 를 식별하기 위한 표준
- Proxy(프락시) 환경에서 client IP 를 얻기

192.168.212.217

클라이언트 A

Squid

웹프록시

192.168.211.39

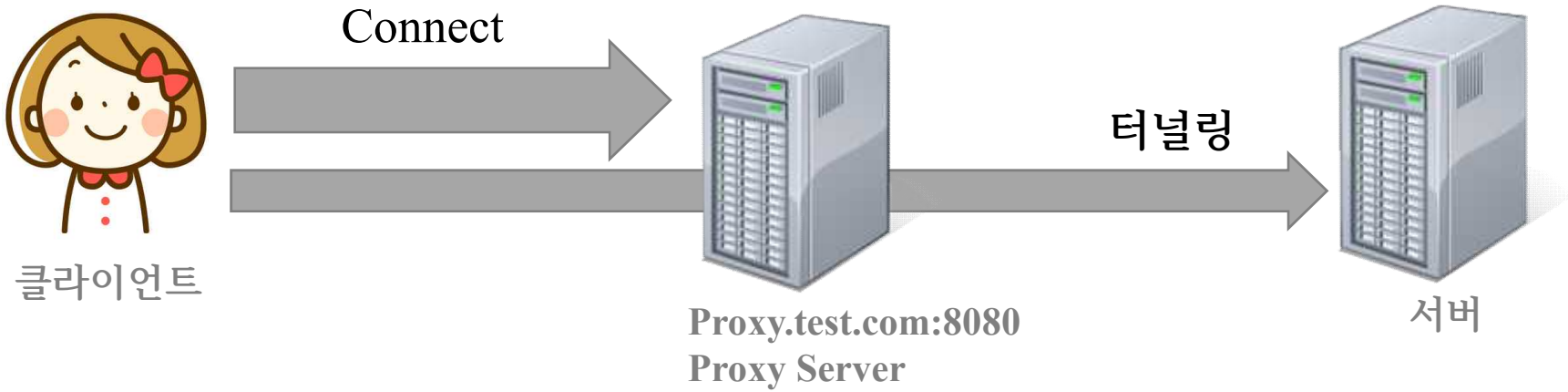
웹서버

```
GET http://192.168.211.39/ HTTP/1.1
Host: 192.168.211.39
Proxy-Connection: keep-alive
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) A
Upgrade-Insecure-Requests: 1
Accept: text/html,application/xhtml+xml,application/xml
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
```

```
GET / HTTP/1.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
Upgrade-Insecure-Requests: 1
Accept: text/html,application/xhtml+xml,application/x
Accept-Encoding: gzip, deflate
Accept-Language: ko-KR,ko;q=0.9,en-US;q=0.8,en;q=0.7
Host: 192.168.211.39
Via: 1.1 Squid (squid/3.5.23)
X-Forwarded-For: 192.168.212.217
Cache-Control: max-age=259200
Connection: keep-alive
```

HTTP Request : Connect 방식

- Proxy와 같은 중계 서버와 사용 시 사용
- 프록시에 터널 접속 확립을 요함으로써 TCP 통신을 터널링 하기 위해 사용
- SSL또는 TLS 등의 프로토콜로 암호화 된 것을 터널링 시키기 위해 사용
- 형식 : CONNECT <u>프록시서버:포트</u> <u>HTTP버전</u>

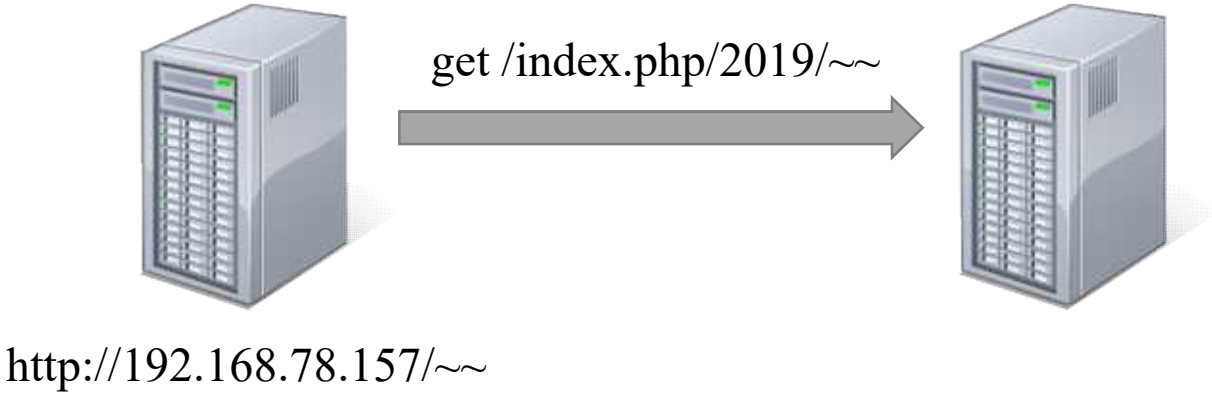


CONNECT proxy.test.com:8080 HTTP /1.1
Host : proxy.testc.om

HTTP Referer

- 현재 사이트에 유입된 경로 표시 (이번 페이지의 URI 정보)
- 현재 표시하는 웹 페이지가 어떤 웹 페이지에서 요청되었는지 알 수 있음
  - 어떤 웹사이트나 웹 서버에서 방문자가 왔는지를 파악 할 수 있는 기능
- **페이지를 요청한 이전 페이지가 무엇인지를 알려주는 정보**
  - **우리 사이트로의 유입이 어떤 검색서비스를 이용한 것인지 알고자**할 때 사용

(예) http://www.A.com/1.html 이라는 웹페이지에 있는 링크를 클릭하여
http://www.B.com/2.html 으로 이동했을 때
referer는 http://www.A.com/1.html 가 됨




```
GET /index.php/2019/12/06/who-wore-it-best-test/ HTTP/1.1
Host: 192.168.78.157
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Referer: http://192.168.78.157/index.php/2019/12/
Connection: close
Upgrade-Insecure-Requests: 1
```

X-XSS-Protection

- Reflected XSS 공격이 탐지되었을때, 웹 페이지가 로딩되는 것을 막아줌
- Internet Explorer, Chrome 및 Safari에서 제공하는 기능

```
X-XSS-Protection: 0

X-XSS-Protection: 1

X-XSS-Protection: 1; mode=block

X-XSS-Protection: 1; report=<reporting-uri>
```

- XSS 필터링을 비활성화
- XSS 필터링을 활성화 (디폴트) : XSS 공격이 감지되면 안전하지 않은 영역을 제거 후 랜더링
- 필터링을 사용 : 공격이 탐지되면 페이지 렌더링 중지
- 필터링을 사용 : 공격을 탐지하면 페이지 렌터링을 차단 후 위반 사황을 보고

X-Content-Type-Option

- MIME 스니핑을 차단하기 위해 사용하는 헤더
- MIME 스니핑 (Content Sniffing)

  - 웹 브라우저가 특정 파일을 읽을 때, 파일의 내용과 Content-type에 설정이 서로 다른 경우 파일의 내용으로부터 파일의 형식을 추측하여 실행하는 것

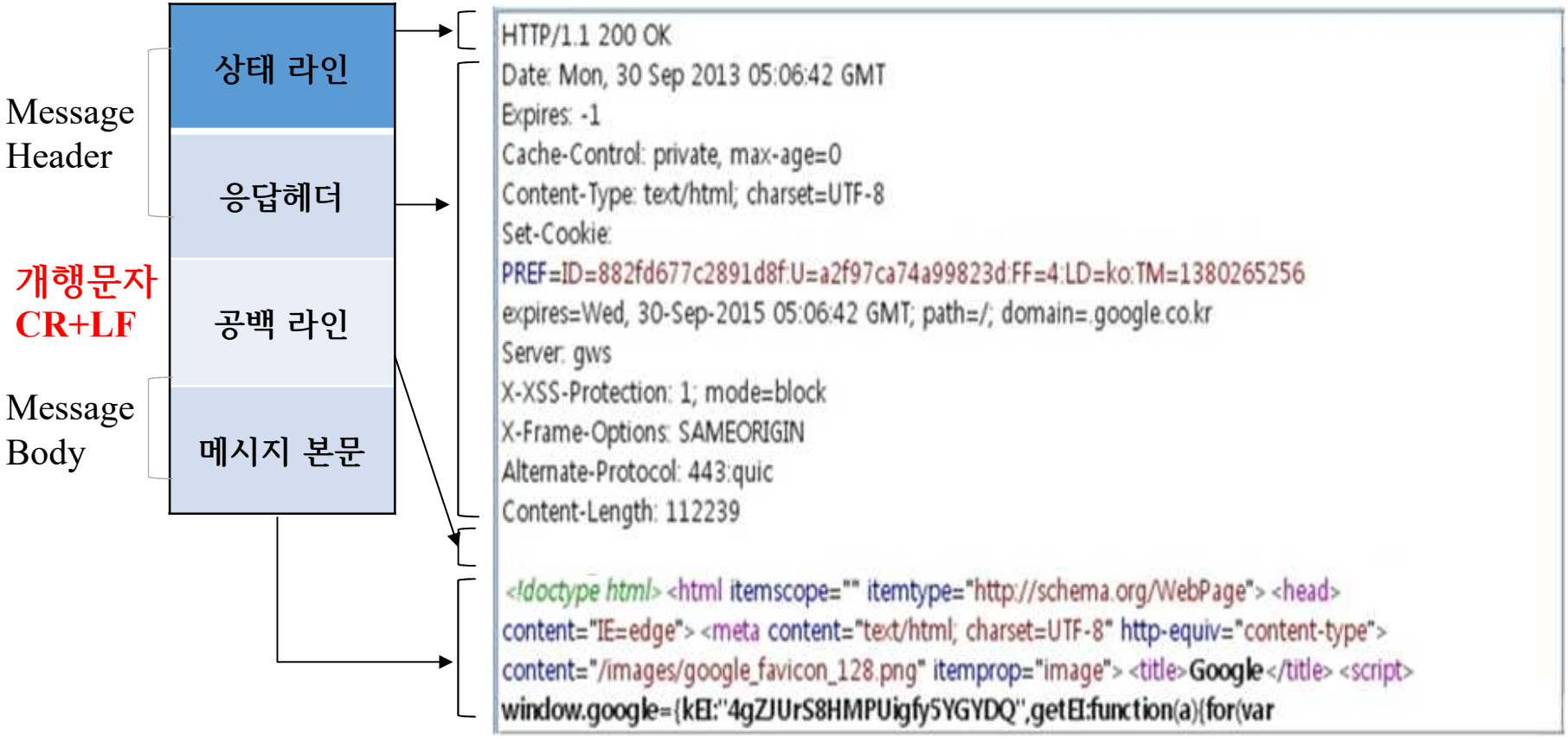
  (예) 공격자가 HTML 코드를 jpg, png 등 이미지 파일로 만들어 업로드

  사용자의 웹 브라우저는 이미지 파일을 요청하더라도, **실제 파일의 내용이 HTML 형식인 것을 보고 HTML 코드를 실행**

  ➔ 공격자가 HTML 코드 내에 악성 자바스크립트를 삽입해두면 XSS 공격을 당할 위협이 있음

```
X-Content-Type-Options: nosniff
```

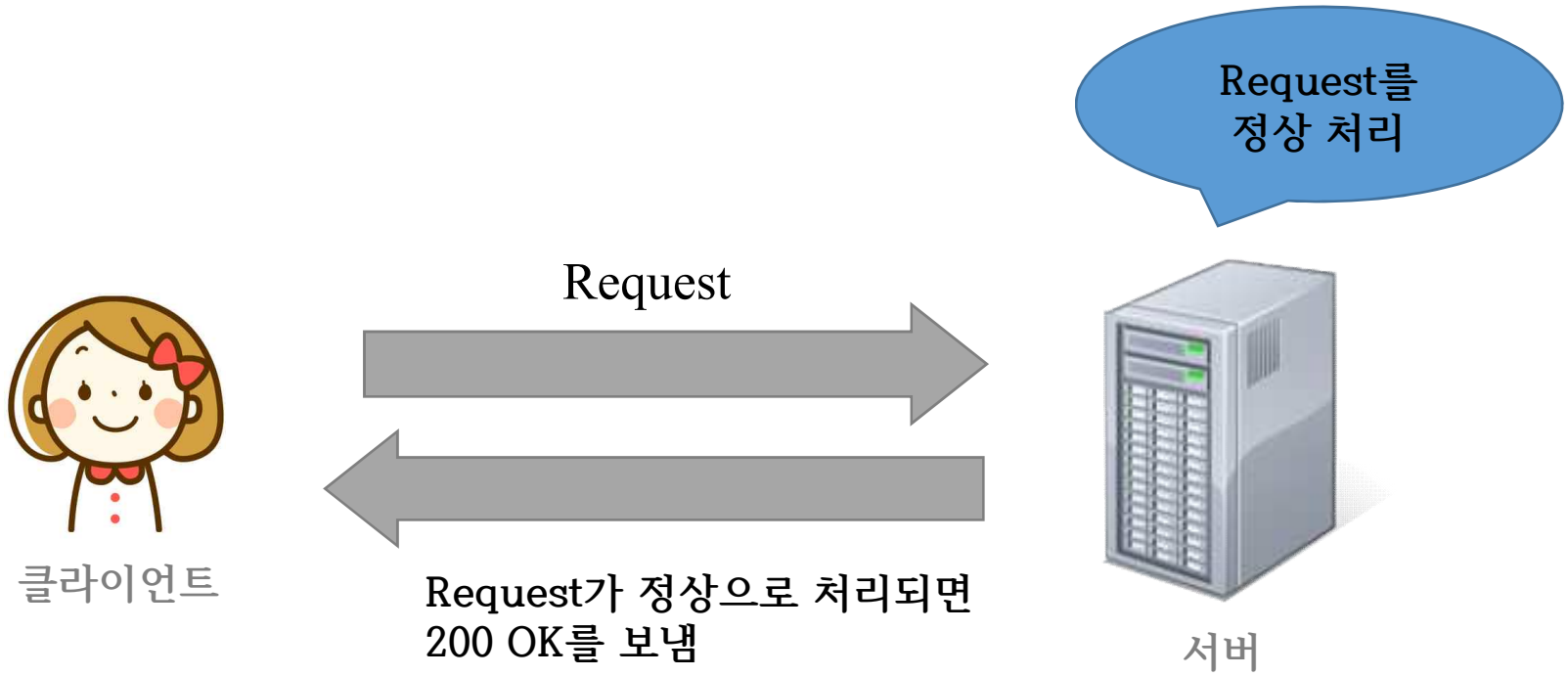
▪ HTTP Response Message



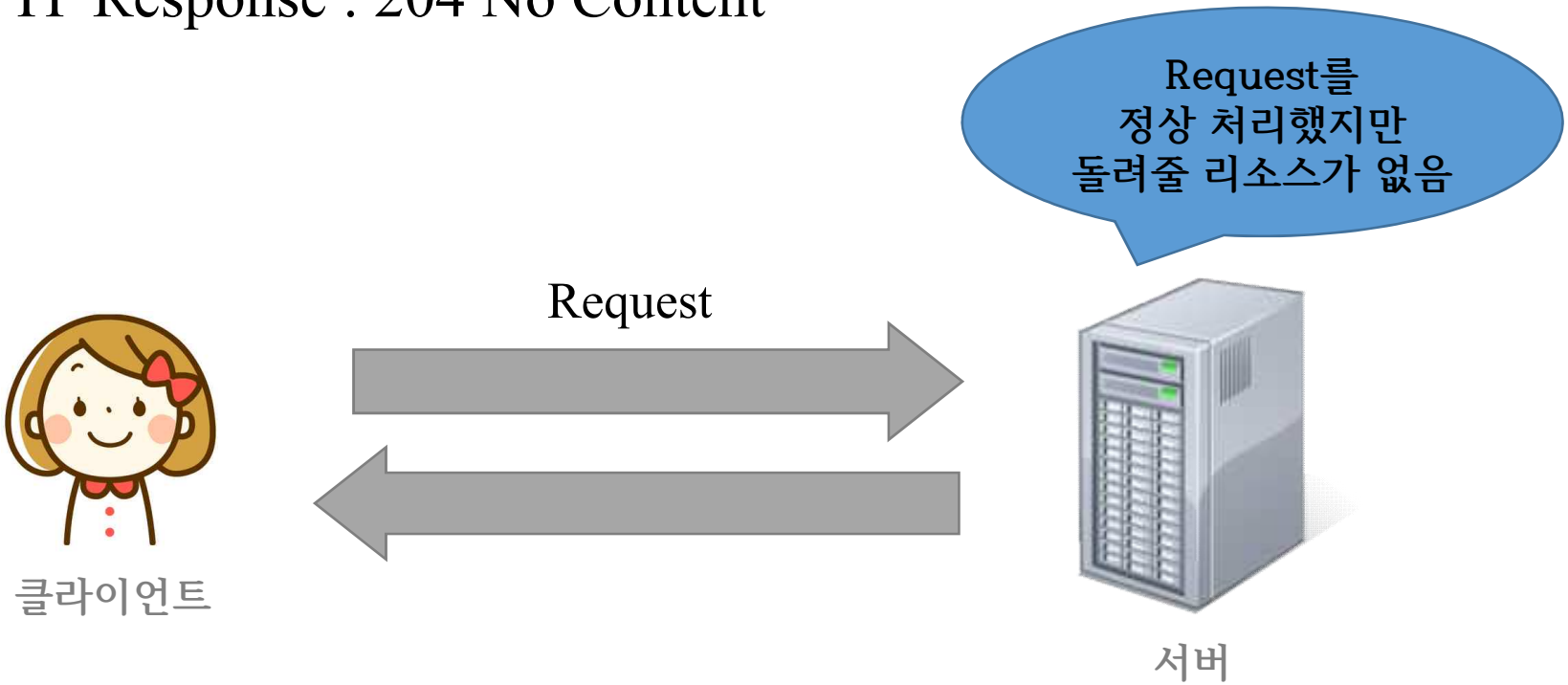
HTTP Response 코드

실행 결과 코드	내용	설명
100번대	정보 전송	HTTP 1.0까지는 계열에 대한 정의가 이루어지지 않았기 때문에 실험 용도 외에는 100번대 서버 측의 응답이 없다.
200번대	성공	클라이언트의 요구가 성공적으로 수신 및 처리되었음을 의미한다.
300번대	리다이렉션	해당 요구 사항을 처리하기 위해 사용자 에이전트가 수행해야 할 추가적인 동작이 있음을 의미한다.
400번대	클라이언트 측 에러	클라이언트에 오류가 발생했을 때 사용한다. 예를 들면 클라이언트가 서버에 보내는 요구 메시지를 완전히 처리하지 못한 경우 등이다.
500번대	서버 측 에러	서버 자체에서 발생한 오류 상황이나 요구 사항을 제대로 처리할 수 없을 때 사용한다.

- HTTP Response : 2XX 성공(Success)



▪ HTTP Response : 204 No Content

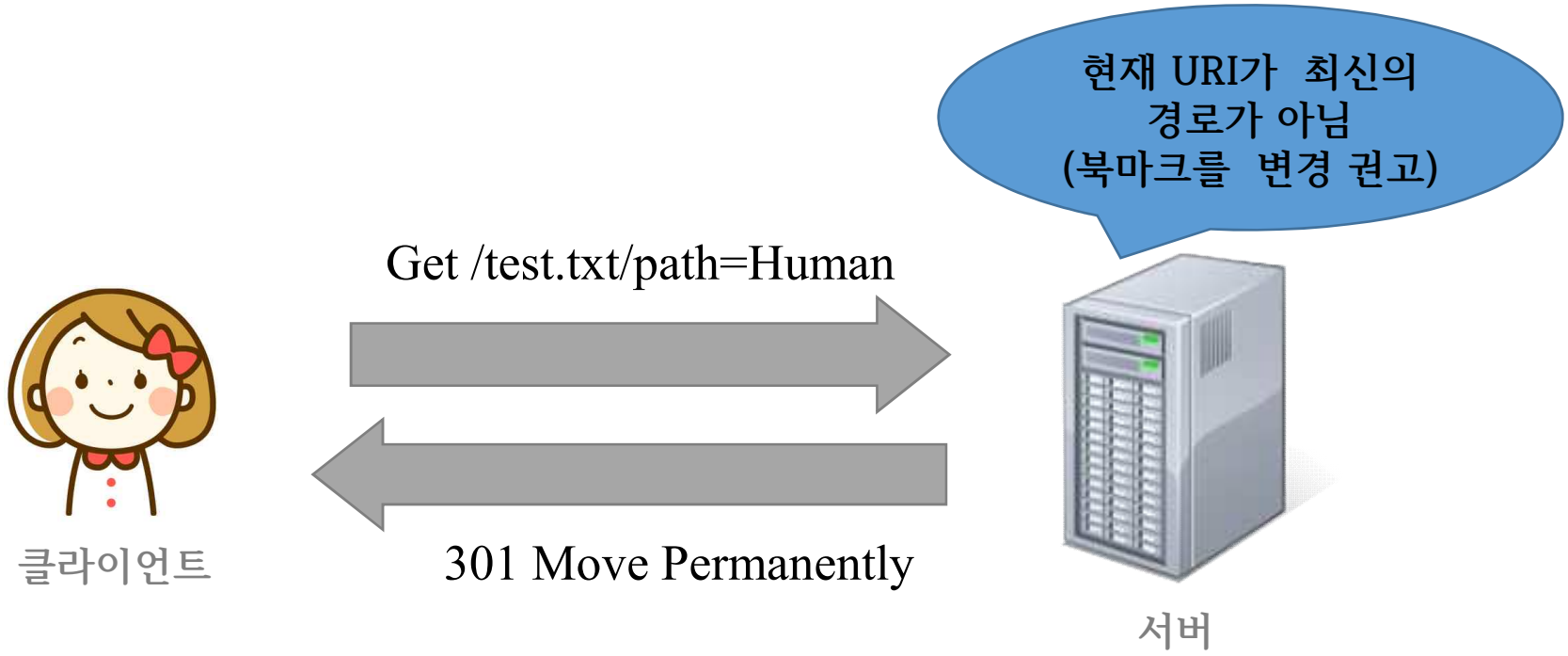


- Request를 받아서 처리하는데 성공했지만 Response에 엔티티 바디를 포함하지 않음
  - 브라우저에서 Request를 보낸 후 204 Response를 수신했어도 표시되어 있는 화면은 변하지 않음
- 클라이언트에 대해 새로운 정보를 보낼 필요가 없는 경우 사용
  - 서버에서 정상적인 변경 또는 삭제 처리가 이루어졌지만 새롭게 보일 정보가 없다는 것을 의미

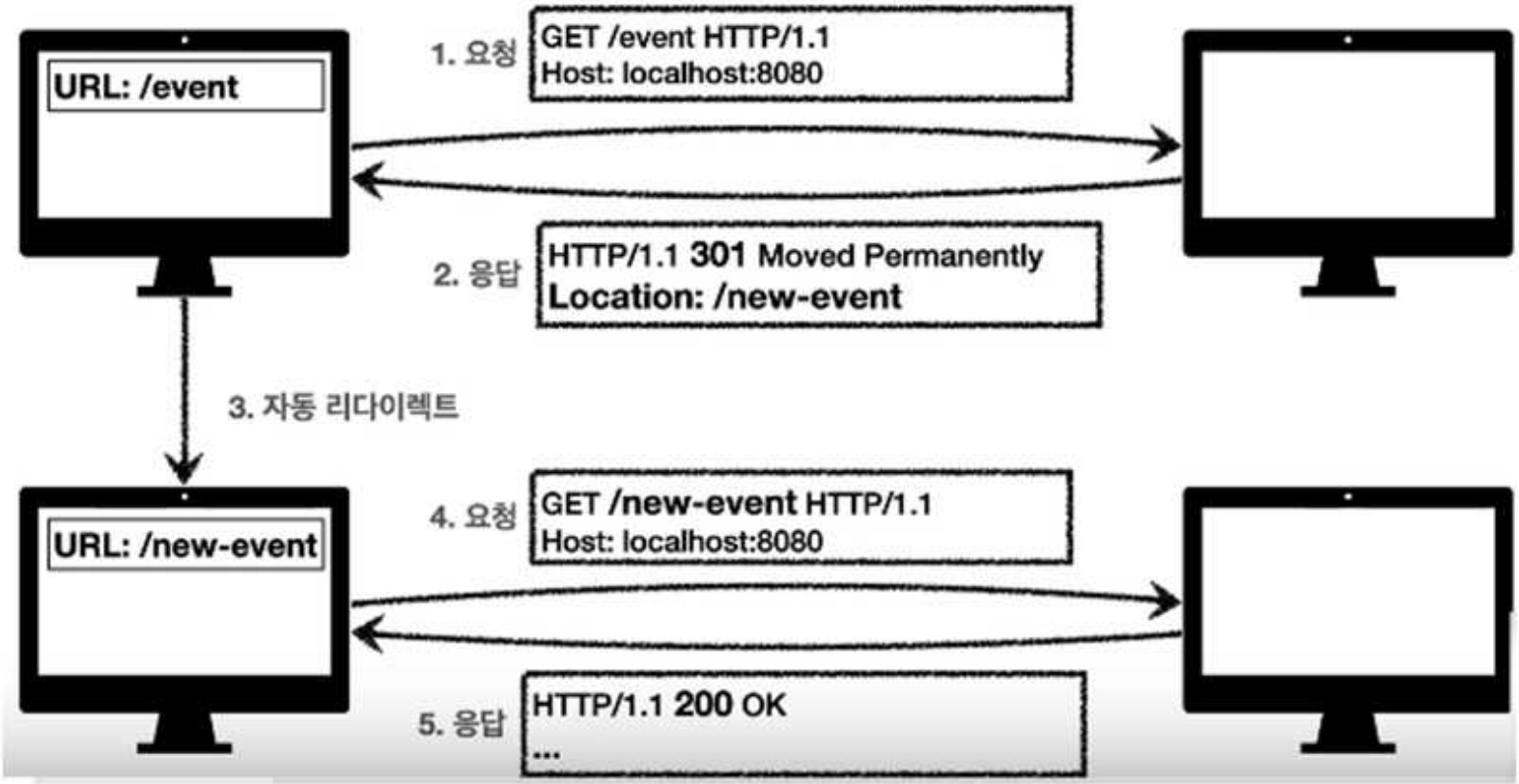
▪ HTTP Response : 3XX Redirection

- 3XX Response는 Request가 정상적으로 처리를 종료하기 위해 브라우저 측에서 특별한 처리를 수행해야 함을 나타냄

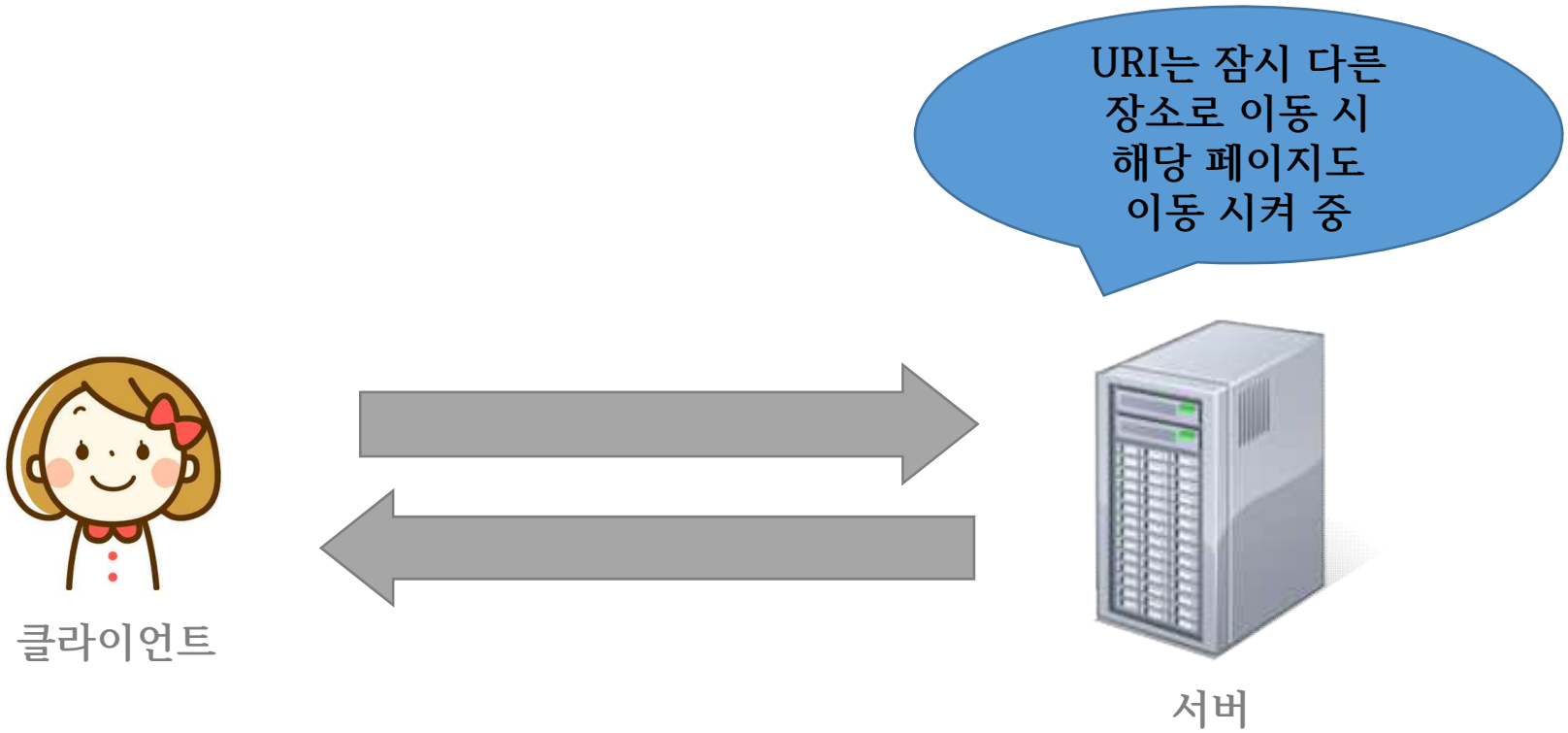
▪ HTTP Response : 301 Moved Permanently



- Request된 리소스에는 새로운 URI가 부여도어 있기 때문에 새로운 URI를 사용해야 한다는 것을 알림
- 북마크하고 있는경우 Location 헤더 필드에서 가리키고 있는 URI로 북마크 권고


URL: /event
1. 요청
GET /event HTTP/1.1
Host: localhost:8080
2. 응답
HTTP/1.1 301 Moved Permanently
Location: /new-event
3. 자동 리다이렉트
URL: /new-event
4. 요청
GET /new-event HTTP/1.1
Host: localhost:8080
5. 응답
HTTP/1.1 200 OK
...

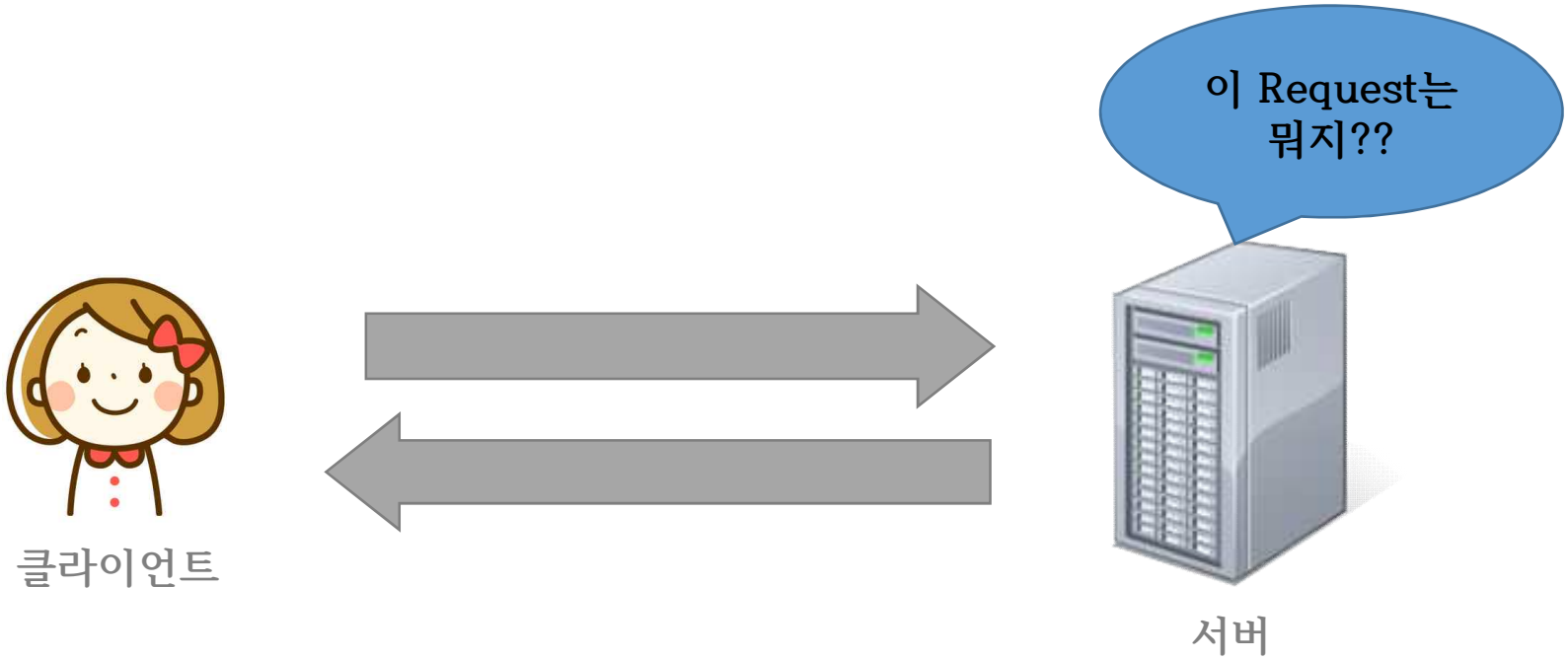
- HTTP Response : 302 Found



- 새로운 URI가 할당되어 있기 때문에 그 URI를 사용하도록 권고
- 301과 비슷하지만 302는 일시적인 이동

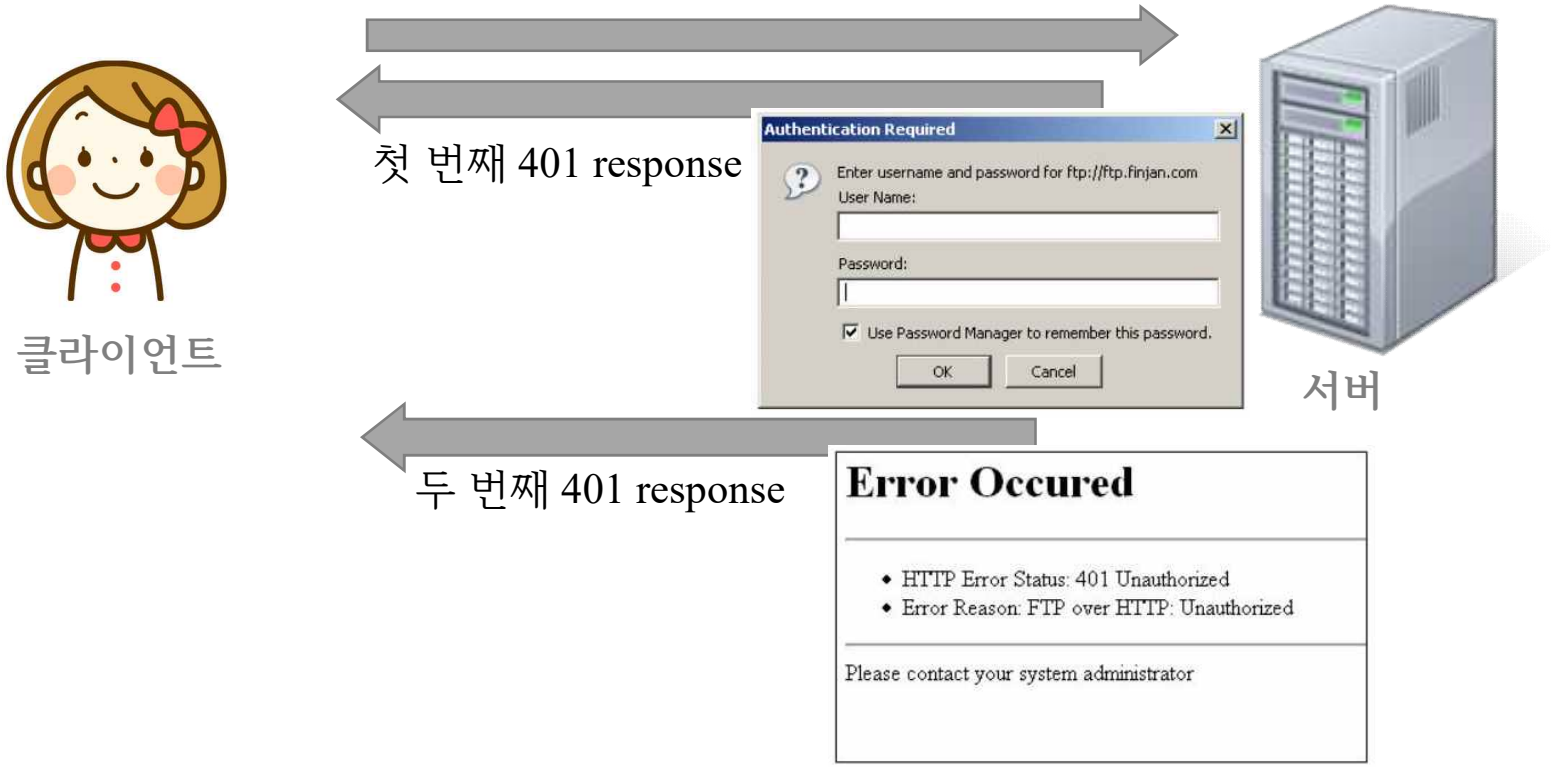
- HTTP Response : 4XX 클라이언트 에러
  - 클라이언트의 원인으로 에러가 발생했음을 나타냄

- HTTP Response : 400 Bad Request



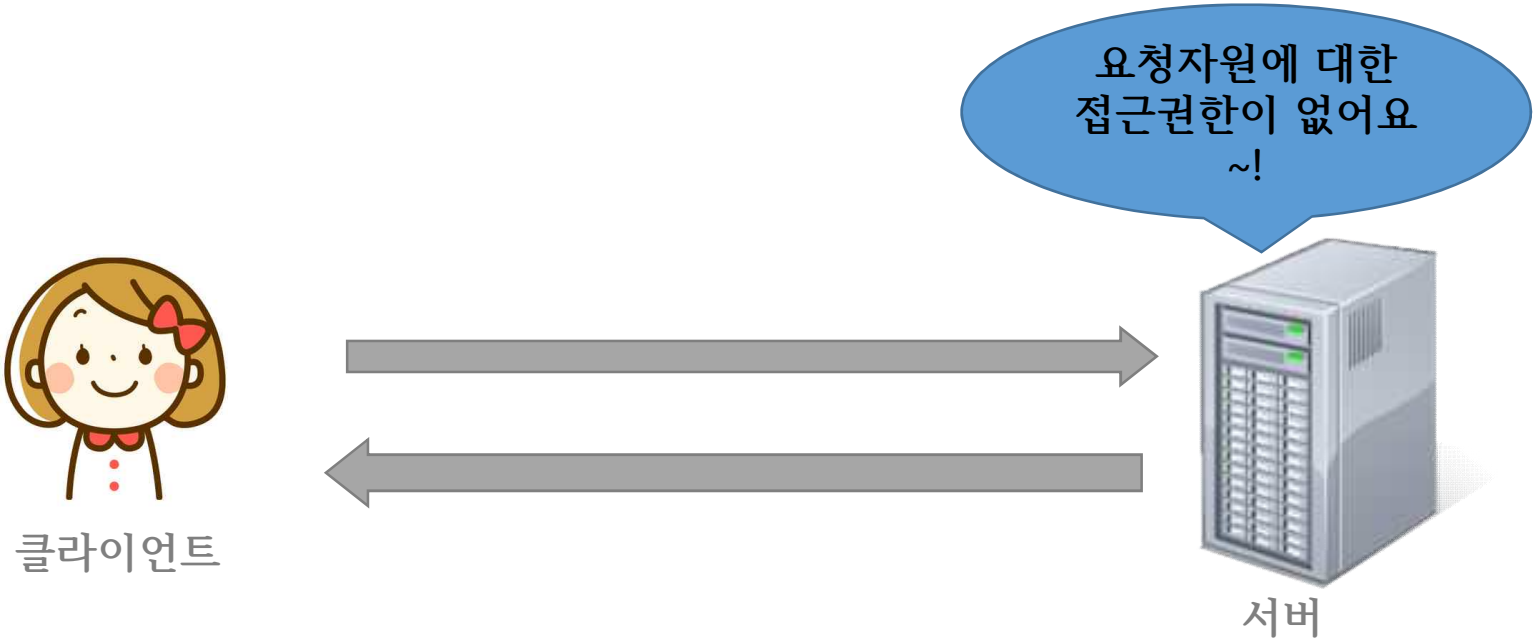
- Request 구문이 잘못되었음 나타냄
- 이 오류가 발생 시 request 내용을 재검토하고 재송신할 필요가 있음

- HTTP Response : 401 Unauthorized



- 401 는 송신한 request에 인증 정보가 필요하다는 것을 나타냄

▪ HTTP Response : 403 Forbidden



- 403 은 요청된 resource의 접근 거부되었음을 의미함

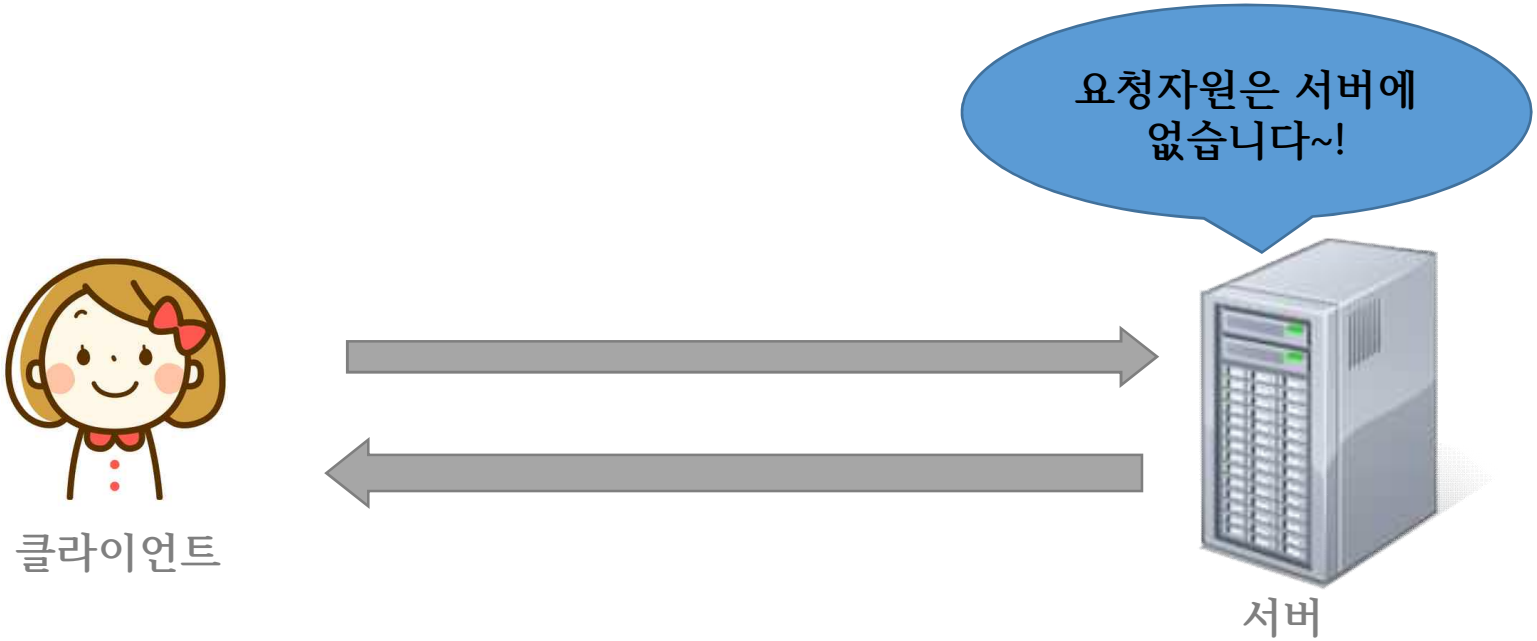
  - 파일 시스템의 권한이 부여되지 않은 경우

  - 액세스 권한(허가되지 않은 송신지 IP주소의 접근 등) 제한이 될 경우

- 서버 측은 거부의 이유를 분명히 할 필요가 있음

- 이유를 명확하게 할 경우에는 body에 기재해서 클라이언트측에 표시

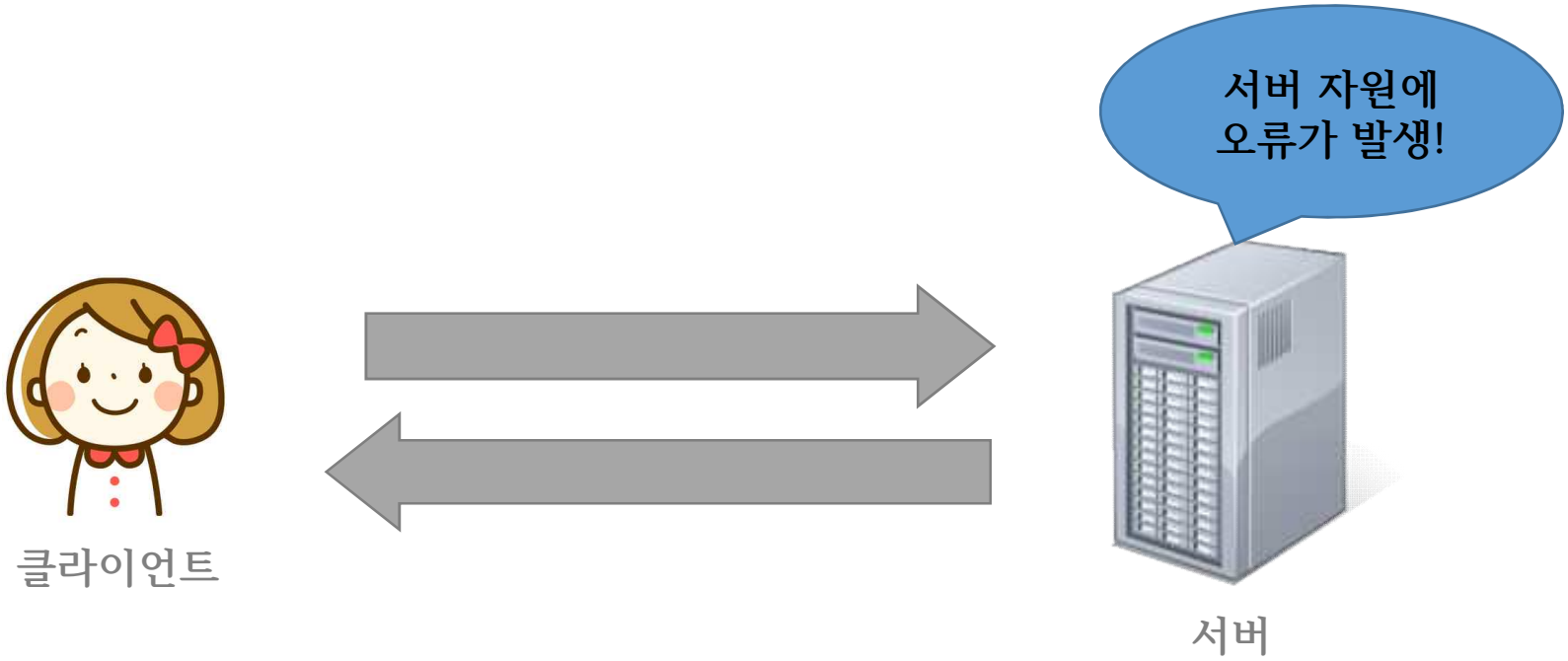
- HTTP Response : 404 Not Found



- Request한 resource가 서버 상에 없음을 나타냄

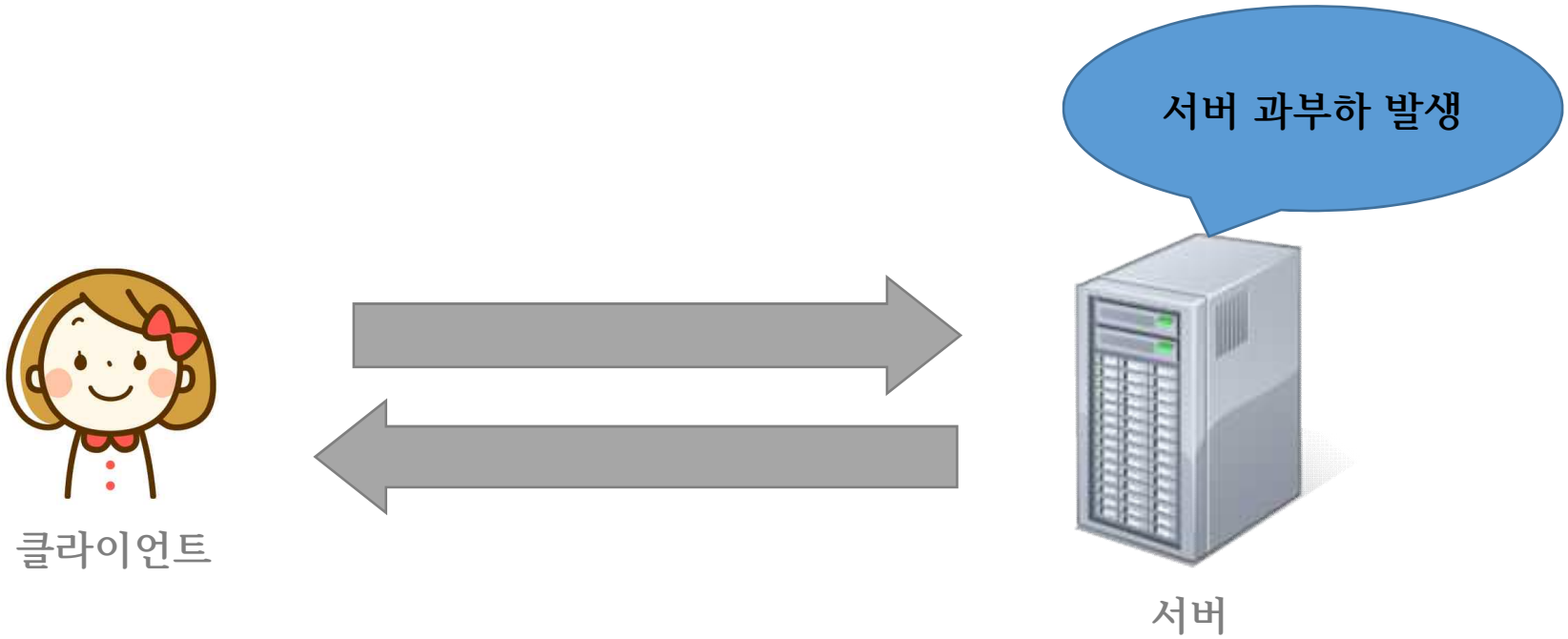
- HTTP Response : 5XX 서버 에러
  - 서버의 원인으로 에러가 발생했음을 나타냄

▪ HTTP Response : 500 Internal Server Error



- Request 처리 도중에 오류가 발생했음을 나타냄
- 웹 애플리케이션에 에러가 발생한 경우나 일시적인 경우도 있음

- HTTP Response : 503 Service Unavaliable



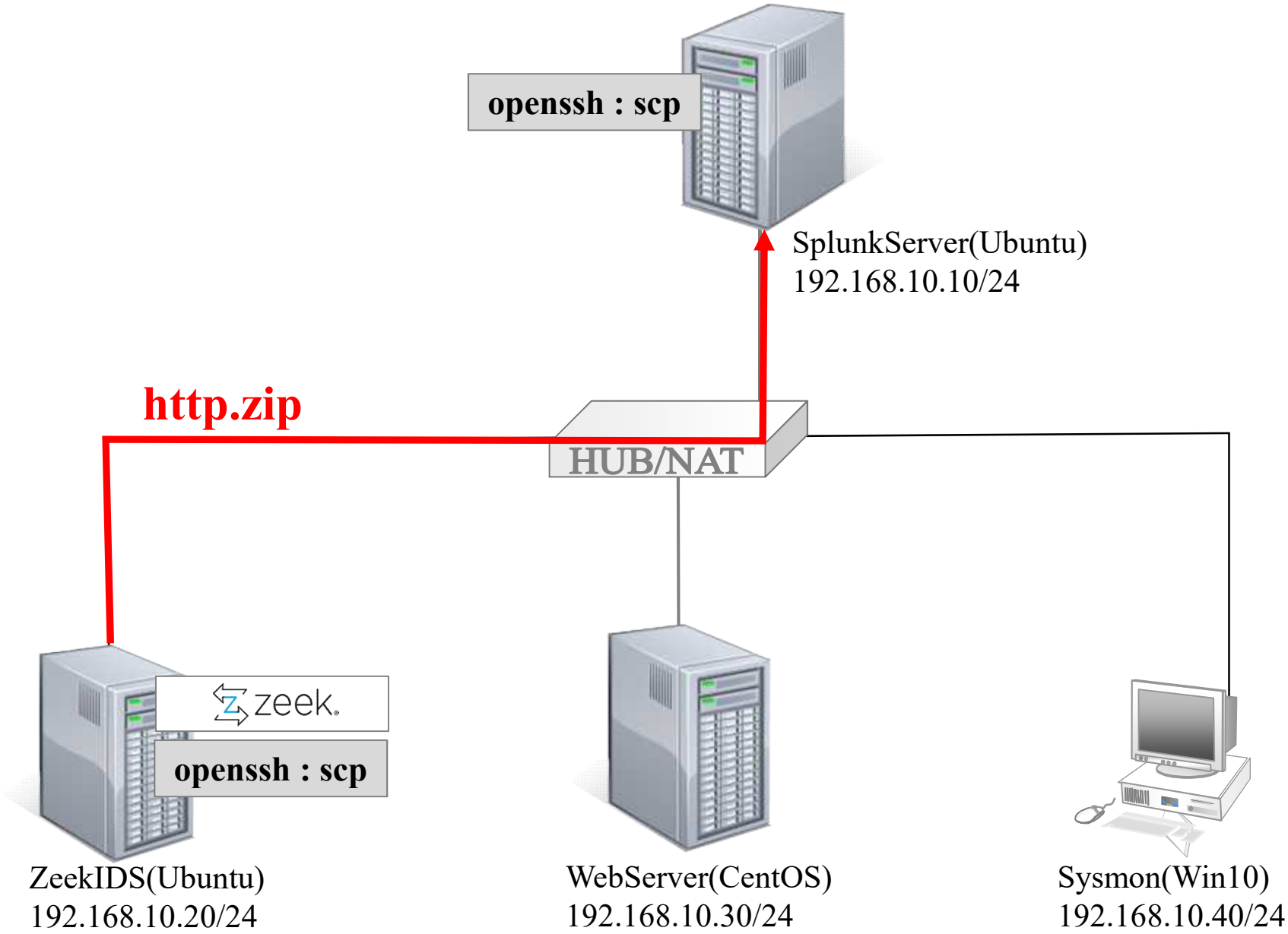
- 일시적으로 서버가 과부하 상태이거나 점검 중임을 나타냄

2) HTTP Log 실습환경 구성

❶ Index 만들기

❷ SourceType 지정

❸ 데이터 추가

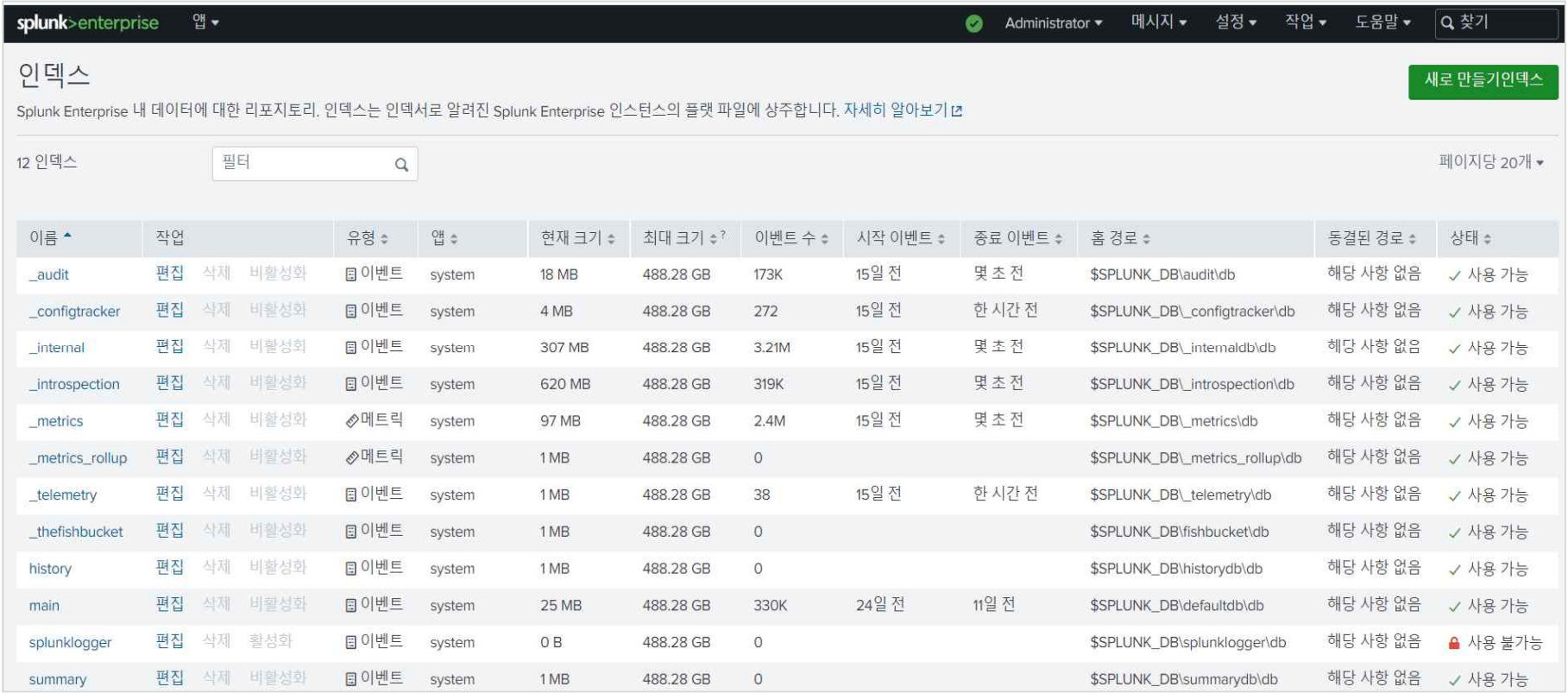

openssh : scp
SplunkServer(Ubuntu)
192.168.10.10/24
http.zip
HUB/NAT
zeek
openssh : scp
ZeekIDS(Ubuntu)
192.168.10.20/24
WebServer(CentOS)
192.168.10.30/24
Sysmon(Win10)
192.168.10.40/24

HTTP 로그 필드

필드명	필드 설명
id.orig_h	송신지IP주소
id.orig_p	송신지 port번호
id.resp_h	수신지IP주소
id.resp_p	수신지 port번호
method	서비스 요청 방식
host	접근 도메인
uri	접근 상세주소 (도메인제외)
referrer	Host 접속시 경유주소
version	HTTP 버전
user-agent	웹브라우저 정보

필드명	필드 설명
request_body_len	서버에게 전송하는 정보길이
response_body_len	사용자에게 전송하는 정보길이
status_code	상태코드
status_msg	상태 메시지
tags	
Proxied	프록시 접속 여부
resp_fuids	연결된 파일 ID
resp_mime_types	전송 파일 mime type

❶ 설정 > 데이터 > 인덱스 > 새로 만들기 인덱스



이름	작업	유형	앱	현재 크기	최대 크기	이벤트 수	시작 이벤트	종료 이벤트	홈 경로	동결된 경로	상태
_audit	편집 삭제 비활성화	이벤트	system	18 MB	488.28 GB	173K	15일 전	몇 초 전	$SPLUNK_DB\audit\db	해당 사항 없음	사용 가능
_configtracker	편집 삭제 비활성화	이벤트	system	4 MB	488.28 GB	272	15일 전	한 시간 전	$SPLUNK_DB_configtracker\db	해당 사항 없음	사용 가능
_internal	편집 삭제 비활성화	이벤트	system	307 MB	488.28 GB	3.21M	15일 전	몇 초 전	$SPLUNK_DB_internaldb\db	해당 사항 없음	사용 가능
_introspection	편집 삭제 비활성화	이벤트	system	620 MB	488.28 GB	319K	15일 전	몇 초 전	$SPLUNK_DB_introspection\db	해당 사항 없음	사용 가능
_metrics	편집 삭제 비활성화	메트릭	system	97 MB	488.28 GB	2.4M	15일 전	몇 초 전	$SPLUNK_DB_metrics\db	해당 사항 없음	사용 가능
_metrics_rollup	편집 삭제 비활성화	메트릭	system	1 MB	488.28 GB	0			$SPLUNK_DB_metrics_rollup\db	해당 사항 없음	사용 가능
_telemetry	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	38	15일 전	한 시간 전	$SPLUNK_DB_telemetry\db	해당 사항 없음	사용 가능
_thefishbucket	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\fishbucket\db	해당 사항 없음	사용 가능
history	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\historydb\db	해당 사항 없음	사용 가능
main	편집 삭제 비활성화	이벤트	system	25 MB	488.28 GB	330K	24일 전	11일 전	$SPLUNK_DB\defaultdb\db	해당 사항 없음	사용 가능
splunklogger	편집 삭제 활성화	이벤트	system	0 B	488.28 GB	0			$SPLUNK_DB\splunklogger\db	해당 사항 없음	사용 불가능
summary	편집 삭제 비활성화	이벤트	system	1 MB	488.28 GB	0			$SPLUNK_DB\summarydb\db	해당 사항 없음	사용 가능

새 인덱스

×

일반 설정

인덱스 이름: httplog

인덱스 이름(예: INDEX_NAME)을 설정하십시오. index=INDEX_NAME을 사용하여 검색하십시오.

인덱스 데이터 유형: 이벤트 | 메트릭

저장할 데이터 유형(이벤트 기반 또는 메트릭)

홈 경로: optional

Hot/warm db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/db).

Cold 경로: optional

Cold db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/colddb).

Thawed 경로: optional

Thawed/resurrected db 경로입니다. 기본적으로 비워 두십시오($SPLUNK_DB/INDEX_NAME/thaweddb).

데이터 무결성 검사: Enable | Disable

Splunk에서 데이터 무결성을 목적으로 데이터의 모든 조각에 대해 해시를 계산하도록 하려면 이 옵션을 활성화합니다.

전체 인덱스의 최대 크기: 500 GB

전체 인덱스의 최대 대상 크기입니다.

Hot/Warm/Cold 버킷의 최대 크기: auto GB

버킷의 최대 대상 크기입니다. 높은 볼륨의 인덱스인 경우 'auto_high_volume'을 입력하십시오.

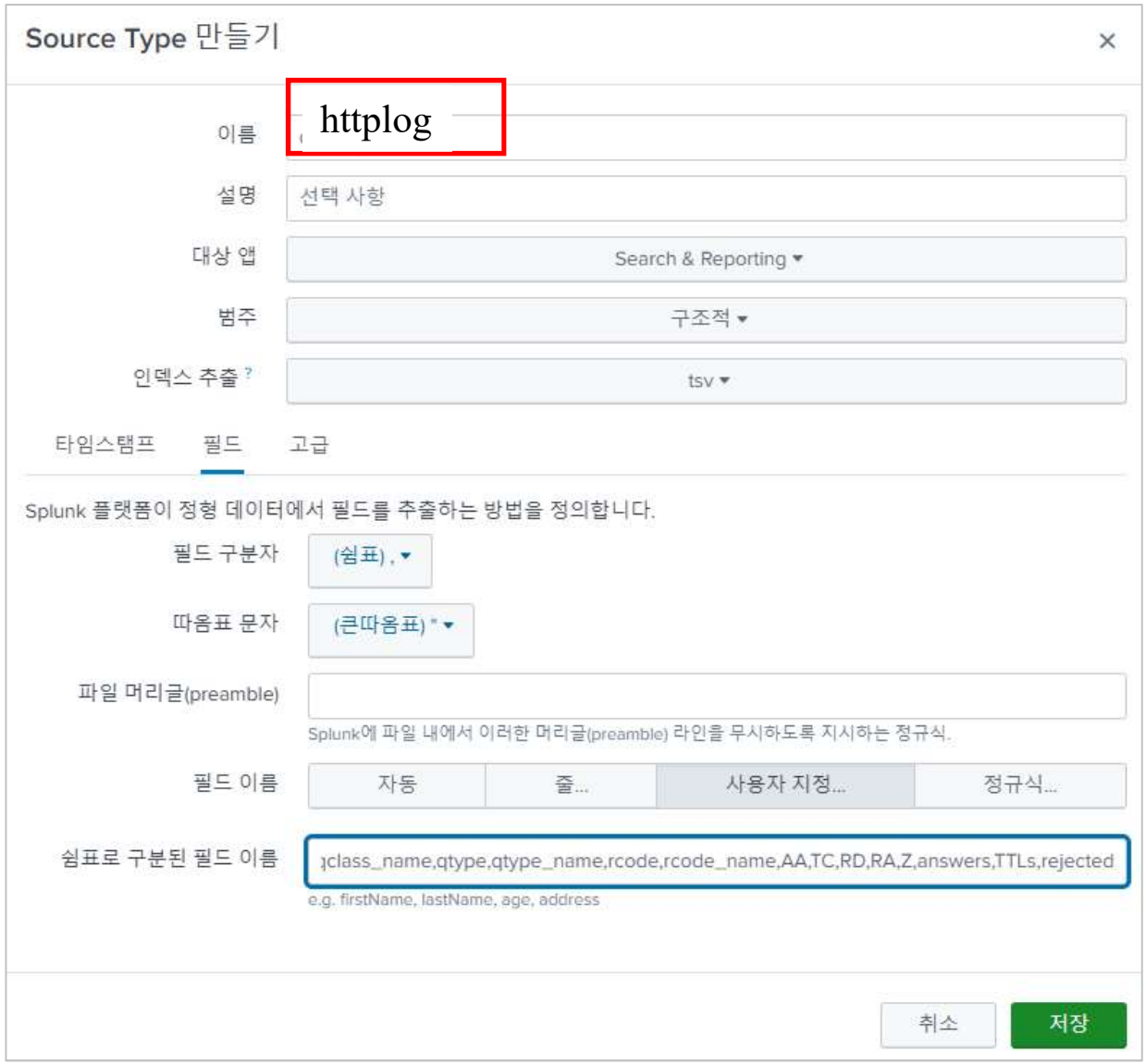
동결된 경로: optional

동결된 버킷 아카이브 경로입니다. Splunk가 동결된 버킷을 자동으로 아카이브하도록 하려면 이 항목을 설정하십시오.

앱: Search & Reporting

저장 | 취소

❷ 설정 > 데이터 > Source Type > 새로 만들기 Source Type



❸ 데이터 추가

데이터 추가
원본 선택
입력 설정
검토
완료
< 뒤로
다음 >
원본 선택
컴퓨터에서 찾아보거나 파일을 끌어서 아래의 대상 상자에 놓는 방법으로 Splunk 플랫폼에 업로드할 파일을 선택합니다. 자세히 알아보기
미리보기는 이 아카이브 파일에 대해 지원되지 않지만, 인덱싱할 수는 있습니다.
선택한 파일:
http.zip
파일 선택

데이터 추가

원본 선택 · 입력 설정 · 검토 · 완료

< 뒤로 | 검토 >

입력 설정

이 데이터 입력에 대해 다음과 같은 추가 매개 변수를 필요에 따라 설정하십시오.

Source type

source type은 Splunk 플랫폼이 모든 수신 데이터에 할당하는 기본 필드 중 하나입니다. 이를 통해 Splunk 플랫폼은 사용자가 어떤 데이터를 갖고 있는지 알고 인덱싱 중에 데이터 형식을 지능적으로 지정할 수 있습니다. source type은 데이터를 쉽게 검색할 수 있게 분류하는 방법이기도 합니다.

자동 | 선택 | 새로 만들기

httlog

호스트

Splunk 플랫폼이 데이터를 인덱싱할 때 각 이벤트는 "host" 값을 수신합니다. 호스트 값은 이벤트가 발생하는 컴퓨터의 이름이어야 합니다. 사용자가 선택한 입력 유형에 따라 사용 가능한 설정 옵션이 결정됩니다. 자세히 알아보기

- (●) 상수 값
- ( ) 경로에 대한 정규식
- ( ) 경로 내 세그먼트

host 필드 값: **WebServer**

인덱스

Splunk 플랫폼은 수신한 데이터를 선택된 인덱스에 이벤트로 저장합니다. 데이터의 source type을 파악하는 데 문제가 있는 경우 "테스트용" 인덱스를 만들어서 사용할 수 있습니다. 테스트용 인덱스를 사용하면 프로덕션 인덱스에 영향을 주지 않고 설정 문제를 해결할 수 있습니다. 나중에 언제든지 이 설정을 변경할 수 있습니다. 자세히 알아보기

인덱스: **httlog** 새 인덱스 만들기

❶ ~ ❸ Index 만들기

데이터 추가
원본 선택
입력 설정
검토
완료
< 뒤로
제출 >
검토
입력 유형 ..... 업로드된 파일
파일 이름 ..... http.zip
Source Type ..... HTTPlog
호스트 DESKTOP-T79SQGC
인덱스 ..... httplog

3) HTTP 네트워크 현황 분석(p.249)

- 내부 인트라넷 서비스/ 인터넷 기반 서비스도 대부분 HTTP로 동작
- HTTP를 분석 시 목적지가 인터넷인지 인트라넷 서비스인지 구분 필요
- 공격자가 **내부망에 침투했다면 중요 데이터의 외부유출을 시도함**

  - **따라서 목적지가 인터넷으로 향하는 HTTP인지 아니면 기업 내부망으로 향하는지가 중요한 기준이 될 수 있음**

HTTP 네트워크 현황 분석 항목

❶ Top 10 접속 도메인, 국가별 접속

❷ Top 10 클라이언트 오류

❸ Top 10 서버 오류

❹ HTTP 상태 코드

❺ HTTP 메소드

❶ Top 10 접속 도메인, 국가별 접속

- 사용자들이 가장 많이 접속하는 도메인을 추출해서 접속현황 분석
- 특정 도메인과 국가로 많은 데이터가 전송되거나 낯선 국가명 등을 모니터링
- 접속 국가 정보를 이상징후의 주요 항목으로 사용

iplocation dst	지역 정보를 iplocation 명령어로 검색
where NOT cidrmatch("0.0.0.0/0", domain)	도메인이 IP주소가 아닌 것을 검색함 cidrmatch함수는 IP주소 형식 검사
sum(request_body_len) as "Outbound", sum(response_body_len) as "Inbound	외부행 전송량을 모두 더해 outbound 필드명으로 저장 내부행 전송량을 모두 더해 Inbound 필드명으로 저장
eval Outbound / eval Inbound	Mb 단위로 변환 (소수2자리까지)
sort Outbound desc	Outbound 역순으로 정렬
head 10	총 10개

```
index=httplog sourcetype=httplog domain!="(empty)"
| iplocation dst
| where NOT cidrmatch("0.0.0.0/0", domain)
| stats sum(request_body_len) as "Outbound", sum(response_body_len) as "Inbound"
by domain, Country
| eval Outbound=round(Outbound/(1024*1024),2)
| eval Inbound=round(Inbound/(1024*1024),2)
| sort Outbound desc
| head 10
```

✓ 1,798,194개의 이벤트 (22/07/19 16:56:41.000 이전) 이벤트 샘플링 없음

이벤트 (1,798,194) 패턴 통계 (10) 시각화

페이지당 20개 형식 미리보기

domain	Country	Outbound	Inbound
speedtest.kdatacenter.com	South Korea	31.77	4337.80
go.microsoft.com	United States	1.14	0.01
go.microsoft.com	Malaysia	1.07	0.00
ispt.ahnlab.com	South Korea	0.99	0.02
dmd.metaservices.microsoft.com	United States	0.90	0.00
analytics21.techsmith.com	United States	0.35	0.04
m.adnxs.com	United States	0.33	0.08
mail2.daum.net	South Korea	0.29	2.17
dmd.metaservices.microsoft.com	Hong Kong	0.22	0.00
m.adnxs.com	Singapore	0.22	0.06

❷ HTTP 메소드

- 클라이언트가 서버에 자원을 요청하는 방식
- 클라이언트는 서버에서 Get 또는 Post를 이용해서 자원 요청
- HTTP 표준에서는 많은 메소드를 지원하지만 **사용자가 많이 사용하지 않는 메소드는 공격자의 정보 수집 행위 등 정상적인 사용 범위가 아닐 수 있음**

uri!="-"	Uri 필드 값이 “-”이 아닌 이벤트 검색
top method limit=10 showperc=f	상위 10개의 메소드 검색 각 값이 차지하는 비율 검색하지 않음

```
index=httplog sourcetype=httplog uri!="-"
| top method limit=10 showperc=f
```

✓ **1,570,141개의 이벤트** (22/07/19 17:00:57.000 이전) 이벤트 샘플링 없음

이벤트 (1,570,141) 패턴 통계 (8) 시각화

페이지당 20개 형식 미리보기

method	count
GET	1545746
POST	17461
HEAD	6564
OPTIONS	187
PUT	102
PROPFIND	79
RCON	1
DELETE	1

❸ Top 10 클라이언트 오류

- HTTP의 상태코드는 클라이언트가 요청한 내용을 서버에서 처리한 결과

status_code >=400 AND status_code < 500	Status_Code가 400이상이거나 500미만인 이벤트 검색

```
index=httplog sourcetype=httplog uri!="-" uri!="/"
(status_code >=400 AND status_code < 500)
| top domain, status_code limit=10 showperc=f
```

✓ **3,005개의 이벤트** (22/07/19 17:07:05.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾

이벤트 (3,005) 패턴 **통계 (10)** 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	status_code	count
iopen.kakaocdn.net	404	387
bambooroot.s3.amazonaws.com	404	325
print-screen.us	404	299
2.tlu.dl.delivery.mp.microsoft.com	403	280
thimg.nateon.nate.com	404	216
crl.starfieldtech.com	404	215
7.tlu.dl.delivery.mp.microsoft.com	403	209
11.tlu.dl.delivery.mp.microsoft.com	403	144
www.baidupcs.com	401	109
theme.whale.naver.net	404	80

❹ Top 10 서버 오류

```
index=httplog sourcetype=httplog uri!="-" status_code >= 500
| top domain, status_code limit=10 showperc=f
```

✓ **89개의 이벤트** (22/07/19 17:11:47.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾

이벤트 (89) 패턴 **통계 (10)** 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	status_code	count
images-cf.taboola.com	502	14
crl.globalsign.net	502	11
dmd.metaservices.microsoft.com	503	10
widgetprovider.daum.net	504	8
realdmp.realclick.co.kr	503	8
cafe.daum.net	500	6
sandoll.dl.cdn.cloudn.co.kr	503	5
dh.serving-sys.com	503	5
ocsp.msocsp.com	502	4
c.hotclick.netinsight.co.kr	503	4

❺ HTTP 상태 코드

```
index=httplog sourcetype=httplog domain!="(empty)" status_code!="-"
| top limit=10 showperc=f status_code
```

✓ **1,563,139개의 이벤트** (22/07/19 17:15:59.000 이전) 이벤트 샘플링 없음

이벤트 (1,563,139) 패턴 **통계 (10)** 시각화

페이지당 20개 형식 미리보기

status_code	count
200	1353089
304	107243
204	58260
302	33048
301	3607
404	2366
408	2169
206	1135
403	922
502	381

HTTP 이상징후(P.275)

❶ 비정상 메소드 사용

❷ 외부행 데이터 전송

❸ Mime-type과 파일 확장자 불일치

❹ 사이트 이동 후 실행파일 다운로드

❺ 프록시 서버 접속

❶ 비정상 메소드 사용

- Head, Delete, Trace, Option 과 같은 메소드가 네트워크에서 지속적으로 보인다는 것은 정상적인 사용자의 활동이라 보기 어려움

```
index=httplog sourcetype=httplog
| stats count(method) by src
```

송신지를 기준으로 접속에 사용한 메소드의 종류별 개수 검색

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

❶ 비정상 메소드 사용

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

✓ **1,803,076개의 이벤트** (22/07/19 17:23:14.000 이전) 이벤트 샘플링 없음

이벤트 (1,803,076) 패턴 통계 (2) 시각화

페이지당 20개 형식 미리보기

src	option_count
172.16.132.81	99
172.16.152.196	15

```
index=httplog sourcetype=httplog
| where NOT match(method, "(GET|POST|-)")
| stats count(src) as src_count by method
| sort - src_count
```

✓ **6,934개의 이벤트** (22/07/19 17:44:05.000 이전) 이벤트 샘플링 없음

이벤트 (6,934) 패턴 **통계 (6)** 시각화

페이지당 20개 형식 미리보기

method	src_count
HEAD	6564
OPTIONS	187
PUT	102
PROPFIND	79
DELETE	1
RCON	1

❷ 외부행 데이터 전송

```
index=httplog sourcetype=httplog
(request_body_len!=0 OR response_body_len!="0") domain!="-"
| stats sum(request_body_len) as outTotal sum(response_body_len) as inTotal by src, dst
| eval oMB=round(outTotal/(1024*1024),2)  | eval iMB=round(inTotal/(1024*1024),2)
| search oMB!=0 AND iMB!=0 | iplocation dst
| eval isUp=if((oMB/iMB)>1, "Yes","No")  | where isUp="Yes"
| table src,dst, iMB, oMB, Country, City
```

✓ **556,655개의 이벤트** (22/07/19 17:52:54.000 이전) 이벤트 샘플링 없음 작업

이벤트 (556,655) 패턴 통계 (9) 시각화

페이지당 20개 형식 미리보기

src	dst	iMB	oMB	Country	City
172.16.129.69	103.243.220.234	0.05	0.10	Singapore	Singapore (Downtown Core)
172.16.129.69	103.243.221.108	0.01	0.12	Singapore	Singapore (Downtown Core)
172.16.129.69	104.254.150.108	0.05	0.19	United States	New York
172.16.129.69	104.254.150.179	0.03	0.13	United States	New York
172.16.132.57	203.205.219.196	0.04	0.08	Hong Kong	Hong Kong
172.16.138.2	67.227.186.229	0.02	0.18	United States	Lansing
172.16.138.2	72.52.161.233	0.02	0.18	United States	Lansing
172.16.143.56	203.205.151.204	0.02	0.03	Singapore	Singapore
172.16.156.145	203.205.128.104	0.01	0.02	Hong Kong	Hong Kong

❸ Mime-type과 파일 확장자 불일치

```
index=httplog sourcetype=httplog resp_mime_types="application/x-dosexec" uri!="-“
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| eval filetype=if(match(filename,"(.exe|.bat|.ps1|.dll|.ocx)$"), "PE", "Not_PE")
| table domain, uri, filename, filetype, resp_mime_types
| where filetype=="Not_PE"
| dedup filename
```

✓ 36개의 이벤트 (22/07/19 18:08:45.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾ 상세 모드 ▾

이벤트 (36) 패턴 통계 (1) 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	uri	filename	filetype	resp_mime_types
gms.ahnlab.com	/jk?c=62&p=j69MFyoH3gPJW19ItJuFDXVJ+14Db6DlXR8dTUgUpus=&k=1	jk	Not_PE	application/x-dosexec

❹ 사이트 이동 후 실행파일 다운로드

```
index=httplog sourcetype=httplog referrer!="-" status_code=200
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| where cidrmatch("0.0.0.0/0",domain)
| where match(resp_mime_types,"application/x-dosexec") OR match(filename,"(exe|dll|com|src)$")
| eval URL=domain+" :: " + filename
| stats count by src, URL
| stats list(URL) as Target list(count) as Source by src
```

✓ **1개의 이벤트** (22/07/19 18:52:28.000 이전) 이벤트 샘플링 없음

이벤트 (1) 패턴 통계 (1) 시각화

페이지당 20개 형식 미리보기

src	Target	Source
172.16.154.10	27.101.137.41 :: PelicanC.dll	1

❺ 프록시 서버 접속

```
index=httplog sourcetype=httplog (uri="http://*" OR method="connect")
| table src, domain, uri
```

✓ **6개의 이벤트** (22/07/19 18:57:19.000 이전) 이벤트 샘플링 없음

이벤트 (6) 패턴 통계 (6) 시각화

페이지당 20개 형식 미리보기

src	domain	uri
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/xbv00200.vdf.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/aevdf.dat.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/ave2-win64-int.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/xvdf.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/savapi4lib-win64-en.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/master.idx

4) HTTP 이상징후(P.275)

❶ 비정상 메소드 사용

❷ 외부행 데이터 전송

❸ Mime-type과 파일 확장자 불일치

❹ 사이트 이동 후 실행파일 다운로드

❺ 프록시 서버 접속

❶ 비정상 메소드 사용

- Head, Delete, Trace, Option 과 같은 메소드가 네트워크에서 지속적으로 보인다는 것은 정상적인 사용자의 활동이라 보기 어려움

```
index=httplog sourcetype=httplog
| stats count(method) by src
```

송신지를 기준으로 접속에 사용한 메소드의 종류별 개수 검색

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

❶ 비정상 메소드 사용

```
index=httplog sourcetype=httplog
| stats count(eval(method="OPTIONS")) AS option_count by src
| where option_count > 10
| sort option_count desc
```

✓ **1,803,076개의 이벤트** (22/07/19 17:23:14.000 이전) 이벤트 샘플링 없음

이벤트 (1,803,076) 패턴 통계 (2) 시각화

페이지당 20개 형식 미리보기

src	option_count
172.16.132.81	99
172.16.152.196	15

```
index=httplog sourcetype=httplog
| where NOT match(method, "(GET|POST|-)")
| stats count(src) as src_count by method
| sort - src_count
```

✓ **6,934개의 이벤트** (22/07/19 17:44:05.000 이전) 이벤트 샘플링 없음

이벤트 (6,934) 패턴 **통계 (6)** 시각화

페이지당 20개 형식 미리보기

method	src_count
HEAD	6564
OPTIONS	187
PUT	102
PROPFIND	79
DELETE	1
RCON	1

❷ 외부행 데이터 전송

```
sourcetype=httplog (request_body_len!=0 OR response_body_len!="0") domain!="-"
```

```
| stats sum(request_body_len) as outTotal sum(response_body_len) as inTotal by src, dst
```

```
| eval oMB=round(outTotal/(1024*1024),2)  | eval iMB=round(inTotal/(1024*1024),2)

| search oMB!=0 AND iMB!=0

| iplocation dst

| eval isUp=if((oMB/iMB)>1, "Yes","No")  | where isUp="Yes"

| table src,dst, iMB, oMB, Country, City
```

❷ 외부행 데이터 전송

```
index=httplog sourcetype=httplog
(request_body_len!=0 OR response_body_len!="0") domain!="-"
| stats sum(request_body_len) as outTotal sum(response_body_len) as inTotal by src, dst
| eval oMB=round(outTotal/(1024*1024),2)  | eval iMB=round(inTotal/(1024*1024),2)
| search oMB!=0 AND iMB!=0 | iplocation dst
| eval isUp=if((oMB/iMB)>1, "Yes","No")  | where isUp="Yes"
| table src,dst, iMB, oMB, Country, City
```

✓ **556,655개의 이벤트** (22/07/19 17:52:54.000 이전) 이벤트 샘플링 없음 작업

이벤트 (556,655) 패턴 통계 (9) 시각화

페이지당 20개 형식 미리보기

src	dst	iMB	oMB	Country	City
172.16.129.69	103.243.220.234	0.05	0.10	Singapore	Singapore (Downtown Core)
172.16.129.69	103.243.221.108	0.01	0.12	Singapore	Singapore (Downtown Core)
172.16.129.69	104.254.150.108	0.05	0.19	United States	New York
172.16.129.69	104.254.150.179	0.03	0.13	United States	New York
172.16.132.57	203.205.219.196	0.04	0.08	Hong Kong	Hong Kong
172.16.138.2	67.227.186.229	0.02	0.18	United States	Lansing
172.16.138.2	72.52.161.233	0.02	0.18	United States	Lansing
172.16.143.56	203.205.151.204	0.02	0.03	Singapore	Singapore
172.16.156.145	203.205.128.104	0.01	0.02	Hong Kong	Hong Kong

❸ Mime-type과 파일 확장자 불일치

```
index=httplog sourcetype=httplog resp_mime_types="application/x-dosexec" uri!="-“
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| eval filetype=if(match(filename,"(.exe|.bat|.ps1|.dll|.ocx)$"), "PE", "Not_PE")
| table domain, uri, filename, filetype, resp_mime_types
| where filetype=="Not_PE"
| dedup filename
```

✓ 36개의 이벤트 (22/07/19 18:08:45.000 이전) 이벤트 샘플링 없음 ▾ 작업 ▾ 상세 모드 ▾

이벤트 (36) 패턴 통계 (1) 시각화

페이지당 20개 ▾ 형식 미리보기 ▾

domain	uri	filename	filetype	resp_mime_types
gms.ahnlab.com	/jk?c=62&p=j69MFyoH3gPJW19ItJuFDXVJ+14Db6DlXR8dTUgUpus=&k=1	jk	Not_PE	application/x-dosexec

❹ 사이트 이동 후 실행파일 다운로드

```
index=httplog sourcetype=httplog referrer!="-" status_code=200
```

```
Hypertext Transfer Protocol
> [truncated]GET /combiner/c?v=201003241632&css=base.201003241632.css,modules.201003241633.c
  Host: a.espncdn.com\r\n
  User-Agent: Mozilla/5.0 (X11; U; Linux i686; en-US; rv:1.9.1.8) Gecko/20100214 Ubuntu/9.10
  Accept: text/css,*/*;q=0.1\r\n
  Accept-Language: en-us,en;q=0.5\r\n
  Accept-Encoding: gzip,deflate\r\n
  Accept-Charset: ISO-8859-1,utf-8;q=0.7,*;q=0.7\r\n
  Keep-Alive: 300\r\n
  Connection: keep-alive\r\n
  Referer: http://espn.go.com/\r\n
  \r\n
```

❹ 사이트 이동 후 실행파일 다운로드

```
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
```

/cgi-bin/PelicanC.dll?impr?pageid=002k&out=iframe

split(uri,"/")

cgi-bin | PelicanC.dll?impr?pageid=002k&out=iframe

filename1=mvindex(split(uri,"/"),-1)

PelicanC.dll | impr | pageid=002k&out=iframe

split(filename1,"?")

filename=mvindex(split(filename1,"?"),0)

❹ 사이트 이동 후 실행파일 다운로드

```
| where cidrmatch("0.0.0.0/0",domain)
```

```
| where match(resp_mime_types,"application/x-dosexec") OR match(filename,"(exe|dll|com|src)$")
| eval URL=domain+" :: " + filename
| stats count by src, URL
| stats list(URL) as Target list(count) as Source by src
```

File name	Mime type
googletoolbarinstaller....exe	application/x-dosexec
..._chrome_installer.exe	application/x-dosexec
GoogleUpdateSetup.exe	application/x-dosexec

❹ 사이트 이동 후 실행파일 다운로드

```
index=httplog sourcetype=httplog referrer!="-" status_code=200
| eval filename1=mvindex(split(uri,"/"),-1)
| eval filename=if(like(filename1,"%?%"), mvindex(split(filename1,"?"),0),filename1)
| where cidrmatch("0.0.0.0/0",domain)
| where match(resp_mime_types,"application/x-dosexec") OR match(filename,"(exe|dll|com|src)$")
| eval URL=domain+" :: " + filename
| stats count by src, URL
| stats list(URL) as Target list(count) as Source by src
```

✓ **1개의 이벤트** (22/07/19 18:52:28.000 이전) 이벤트 샘플링 없음

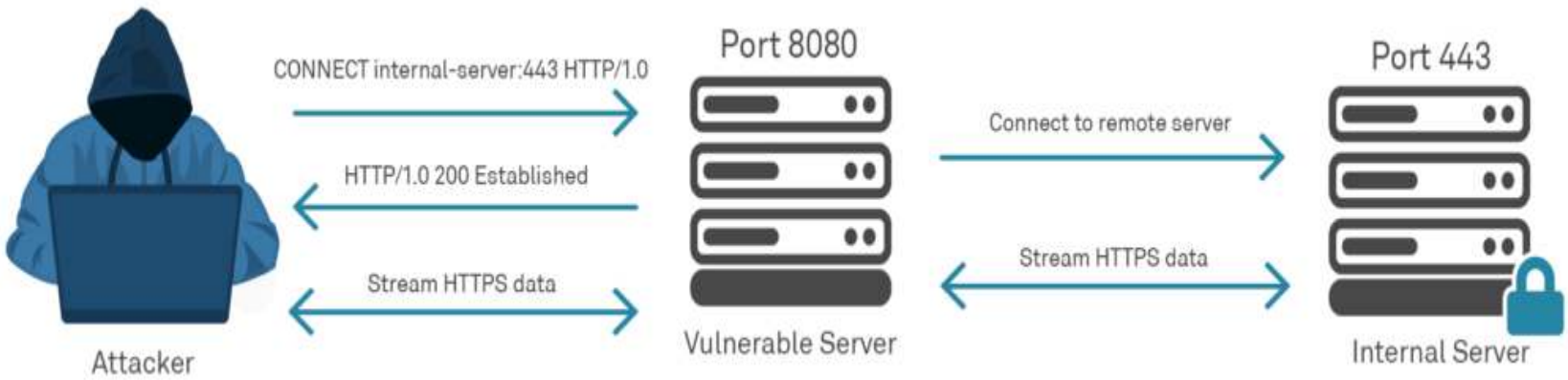
이벤트 (1) 패턴 통계 (1) 시각화

페이지당 20개 형식 미리보기

src	Target	Source
172.16.154.10	27.101.137.41 :: PelicanC.dll	1

Proxy Server

- Connect method : 웹서버에 Proxy 기능을 요청 시 사용




```
> Frame 43: 291 bytes on wire (2328 bits), 291 bytes captured (2328 bits) on interface \Device\NPF_{BD0DBB8D-64FC-47A9-
> Ethernet II, Src: VMware_5f:2c:a1 (00:0c:29:5f:2c:a1), Dst: Fortinet_99:4a:b3 (70:4c:a5:99:4a:b3)
> Internet Protocol Version 4, Src: 194.247.5.7, Dst: 85.25.246.38
> Transmission Control Protocol, Src Port: 57556, Dst Port: 8080, Seq: 1, Ack: 1, Len: 237
v Hypertext Transfer Protocol
  v CONNECT weberblog.net:443 HTTP/1.1\r\n
    > [Expert Info (Chat/Sequence): CONNECT weberblog.net:443 HTTP/1.1\r\n]
      Request Method: CONNECT
      Request URI: weberblog.net:443
      Request Version: HTTP/1.1
    Host: weberblog.net:443\r\n
    Proxy-Connection: keep-alive\r\n
    User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/88.0.4324.96 S
    \r\n
    [Full request URI: weberblog.net:443]
    [HTTP request 1/1]
    [Response in frame: 45]
```

HTTPS Connection through a proxy:
method: CONNECT,
while URI lists only the host (without the path)

Proxy Server

- URI에 접속 대상의 전체 주소가 기록 된 경우

  * 클라이언트가 자체적으로 프록시를 설정하고 운영하는 경우

Attacker

uri
http://updates.cdc.carbonblack.io/update/x_vdf/xbv00200.vdf.gz
http://updates.cdc.carbonblack.io/update/x_vdf/aevdf.dat.gz
http://updates.cdc.carbonblack.io/update/idx/ave2-win64-int.info.gz
http://updates.cdc.carbonblack.io/update/idx/xvdf.info.gz
http://updates.cdc.carbonblack.io/update/idx/savapi4lib-win64-en.info.gz
http://updates.cdc.carbonblack.io/update/idx/master.idx

❺ 프록시 서버 접속

```
index=httplog sourcetype=httplog (uri="http://*" OR method="connect")
| table src, domain, uri
```

✓ **6개의 이벤트** (22/07/19 18:57:19.000 이전) 이벤트 샘플링 없음

이벤트 (6) 패턴 통계 (6) 시각화

페이지당 20개 형식 미리보기

src	domain	uri
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/xbv00200.vdf.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/x_vdf/aevdf.dat.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/ave2-win64-int.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/xvdf.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/savapi4lib-win64-en.info.gz
172.16.156.145	updates.cdc.carbonblack.io	http://updates.cdc.carbonblack.io/update/idx/master.idx